UNITÉ D'ÉTUDE QUATRE : GESTION DES RISQUES

Cette unité d'étude est la deuxième d'une série de quatre portant sur le **domaine V : Gouvernance, gestion des risques et contrôle** du programme d'examens CIA de l'IIA. Ce domaine représente 35 % de la partie 1 de l'examen de l'ICA et est évalué aux niveaux cognitifs de **base** et de **compétence. La** partie pertinente du syllabus est mise en évidence ci-dessous. (Le programme complet se trouve à l'annexe B.)

	Gouvernance, gestion des risques et contrôle (35 %)		
	A	Décrire le concept de gouvernance organisationnelle	De base
	B	Reconnaître l'impact de la culture organisationnelle sur l'environnement de contrôle global et sur les risques et les contrôles de l'engagement individuel.	De base
	C	Reconnaître et interpréter les questions liées à l'éthique et à la conformité de l'organisation, les violations présumées et les dispositions.	De base
	D	Décrire la responsabilité sociale de l'entreprise	De base
V	**E**	**Interpréter les concepts fondamentaux du risque et le processus de gestion du risque**	**Compétent**
	F	**Décrire les cadres de gestion des risques acceptés à l'échelle mondiale qui conviennent à l'organisation (COSO - ERM, ISO 31000, etc.).**	**De base**
	G	**Examiner l'efficacité de la gestion des risques au sein des processus et des fonctions**	**Compétent**
	H	**Reconnaître la pertinence du rôle de l'activité d'audit interne dans le processus de gestion des risques de l'organisation.**	**De base**
	I	Interpréter les concepts de contrôle interne et les types de contrôles	Compétent
	J	Appliquer des cadres de contrôle interne globalement acceptés et adaptés à l'organisation (COSO, etc.)	Compétent
	K	Examiner l'efficacité et l'efficience des contrôles internes	Compétent

I. TECHNIQUES DE GESTION DES RISQUES

1. Le risque est «la survenue possible d'un événement affectant la réalisation des objectifs. Le risque est mesuré en termes d'impact et de probabilité » (Glossaire IIA).

Le management des risques est « un processus permettant d'identifier, d'évaluer, de gérer et de contrôler les événements ou les situations susceptibles de fournir une assurance raisonnable quant à la réalisation des objectifs de l'organisation » (Glossaire de l'IIA). Il s'agit de l'un des trois processus spécifiquement définis dans la définition de l'audit interne.

D'après le texte Audit interne : Services de conseil et d'assurance, nous pouvons établir les points supplémentaires suivants concernant le risque.

- **Le risque prend ses origines dans la formulation de stratégies et l'établissement des objectifs.** Deux organisations n'étant jamais identiques, chaque entreprise possède une stratégie et des objectifs uniques et affronte un type de risque différent.
- **Le risque ne peut pas être estimé en un point ; il représente une gamme de possibilités.** En l'absence de résultat unique, la gamme de possibilités crée l'incertitude quant à la compréhension et à l'évaluation du risque.
- **Le risque peut concerner le fait d'empêcher l'apparition d'éléments négatifs ou d'échouer à faire apparaître des éléments positifs.** Les risques peuvent présenter des menaces pour une organisation ou être constitués par l'absence de résultats positifs.
- **Les risques sont inhérents à tous les aspects de la vie ; les risques associés à une activité commerciale sont considérés comme des risques commerciaux**. Les risques commerciaux sont les incertitudes associées à la réalisation des objectifs commerciaux.

Norme de fonctionnement 2120 Gestion des risques : L'audit interne doit évaluer l'efficacité des processus de management des risques et contribuer à leur amélioration.

2. Le processus de management des risques - Vue d'ensemble

Les processus de management des risques comprennent (1) l'identification du contexte, (2) l'identification des risques, (3) l'évaluation et la priorisation des risques, (4) la réponse aux risques, et (5) la surveillance des risques. La direction doit se concentrer sur les risques à tous les niveaux de l'entité et prendre les mesures nécessaires pour les gérer. Tous les risques susceptibles d'affecter la réalisation des objectifs doivent être pris en compte.

Étape 1 - Identification du contexte

Une condition préalable à l'identification des risques est l'identification des contextes significatifs dans lesquels les risques doivent être gérés. Les contextes comprennent les éléments suivants :

- Lois et règlements
- Projets d'immobilisations
- Les processus d'affaires

- Technologie
- Risque de marché (p. ex. taux d'intérêt, taux de change, placements en actions)
- Organisations

Étape 2 - Identification des risques

L'identification des risques doit être effectuée à tous les niveaux de l'entité (niveau de l'entité, division, unité opérationnelle) pertinents pour le (s) contexte (s) identifié (s).

- Les exemples de facteurs de risque externes au niveau de l'entité comprennent les changements technologiques et les changements dans les désirs et les attentes des clients.
- Les exemples de facteurs de risque internes au niveau de l'entité comprennent (1) les interruptions dans les systèmes automatisés, (2) la qualité du personnel recruté et (3) le niveau de formation fourni.

Certaines occurrences peuvent être sans conséquence au niveau de l'entité mais désastreuses pour une unité individuelle. L'identification des risques doit tenir compte des événements passés (tendances) et des possibilités futures. Les méthodes utilisées sont les suivantes :

Technique	Description	Exemple
Inventaires des événements	Listes détaillées des événements potentiels communs aux entreprises d'un secteur industriel donné, ou à un processus ou une activité commune aux différents secteurs industriels	Logiciels générant des listes d'événements potentiels génériques fréquemment rencontrés dans un projet d'édition de logiciel personnalisé
Analyse interne	• Analyse détaillée des informations • Peut être incluse dans les opérations de routine ou utiliser des informations provenant d'autres parties prenantes (p. ex. d'autres unités d'affaires, clients ou fournisseurs}, ou de sources internes ou externes	Analyse de lancement d'un nouveau produit examinant les données historiques internes ainsi que les événements influant sur la réussite des produits concurrents
Escalade ou seuils de déclenchement	• Seuils de déclenchement d'une alerte à destination de la direction concernant des domaines susceptibles de nécessiter une évaluation plus approfondie ou une réponse immédiate • Comparaison des transactions ou des événements actuels selon des critères prédéfinis	Suivi des prix de la concurrence et analyse de la structure de tarification de l'organisation lorsqu'un concurrent atteint un seuil donné

Entretiens et ateliers animés	Discussions structurées dirigées par un facilitateur et destinées à exploiter les connaissances et les expériences collectives de la direction, du personnel et des autres parties prenantes concernant les événements susceptibles d'avoir une incidence sur la réalisation des objectifs d'une entité ou d'une unité	Groupe de discussion composé de membres du service comptable et animé par un contrôleur financier ayant pour objectif d'identifier les événements ayant un impact sur le reporting financier externe de l'organisation
Analyse de processus	• Identifie la combinaison des entrées, des tâches et des responsabilités dans un processus • Prise en compte des facteurs internes et externes qui affectent les entrées ou les activités d'un processus • Identification des événements qui peuvent influer sur la réalisation des objectifs d'un processus	Laboratoire médical établissant des cartes de processus pour la réception et le test d'échantillons, puis évaluant ces cartes dans le but d'identifier les risques potentiels
Indicateurs d'événements principaux	Surveillance des données corrélées aux événements pour identifier les conditions pouvant donner naissance à un événement.	Institution financière surveillant les schémas de remboursement des prêts afin d'identifier les retards de paiement et de réduire le risque de défaut de paiement en agissant à temps
Méthodologies des données liées à des événements de perte	• Examen des données concernant des événements de perte passés dans le but d'identifier des tendances et les causes premières de ces événements • Permettent d'évaluer plus facilement s'il est préférable de traiter la cause d'origine que chacun des événements	Compagnie d'assurance examinant une base des données historiques d'accidents pour identifier la cause d'origine des déclarations de sinistre

Les autres méthodes d'identification des risques sont (a) le brainstorming, (b) l'analyse SWOT (forces, faiblesses, opportunités et menaces) et (c) l'analyse de scénarios (analyse de simulation).

- **Interdépendance des événements**

Lors de l'identification des événements, la direction doit tenir compte de la façon dont les événements interagissent. Les événements sont rarement isolés. Par exemple, les incitations liées à la performance peuvent augmenter la productivité, mais elles peuvent aussi aboutir à des pratiques de reporting frauduleux.

- **Distinction entre les risques et les opportunités**

Une fois les principaux événements et facteurs d'influence identifiés, la direction peut déterminer si le potentiel est positif ou négatif. Dans certains cas, un événement peut présenter ces deux aspects. Les opportunités positives sont réintégrées dans la stratégie et le processus de mise en place des objectifs. Les événements ayant un impact négatif qui représentent un risque devront être évalués en profondeur afin de déterminer la réponse à apporter.

Étape 3 - Évaluation et priorisation des risques

Le processus d'évaluation des risques peut être formel ou informel. Cela implique

- Évaluer l'impact d'un événement,
- Évaluer la probabilité de l'événement, et
- Envisager les moyens de gérer le risque.

Facteurs courants de probabilité et d'impact

Facteurs de probabilité	Facteurs d'impact
• Estimations de probabilité historiques ou cycliques • Complexité des activités • Changement ou stabilité (p. ex. rotation des employés ou nouvelles lois) • Environnement de contrôle (p. ex. intégrité et éthique) • Efficacité du processus de contrôle	• Seuil d'importance relative (p. ex. perte monétaire) • Dommages potentiels à la réputation ou à la marque • Importance de l'objectif associé pour la mission de l'organisation • Vitesse de survenue, durée et / ou omniprésence de l'événement • Coûts de reprise

Les résultats de l'évaluation de la probabilité et de l'impact des événements de risque identifiés sont utilisés pour hiérarchiser les risques et produire des informations décisionnelles.

Les méthodes d'évaluation des risques peuvent être qualitatives ou quantitatives.

- Les méthodes qualitatives comprennent (1) les listes de tous les risques, (2) les classements des risques et (3) les cartes des risques.
    - ✓ Les cartes de chaleur présentent les niveaux de risque par couleur. Risques qui ont la même probabilité (par exemple, éloignée, improbable, possible, probable ou certaine) et l'impact (par exemple, négligeable, faible, moyen, élevé ou extrême) ou qui se situent dans la même fourchette de gravité (c.-à-d. évaluation de la probabilité et de l'impact), se voient attribuer la même couleur.
    - ✓ Les cartes matricielles des risques présentent les risques sur un graphique avec une probabilité sur un axe et un impact sur l'autre axe.

- Les méthodes quantitatives incluent des modèles probabilistes. Par exemple, certaines organisations se concentrent sur les revenus à risque en examinant comment les variables influent sur les gains.

Ci – dessous les techniques d'évaluation quantitative des risques

Analyse comparative

Un processus de collaboration qui utilise des paramètres communs pour comparer les mesures et les résultats de performance d'événements ou de processus spécifiques pour identifier les opportunités d'amélioration. Il peut également être utilisé pour évaluer la probabilité et l'impact des événements potentiels dans un secteur industriel. Voici quelques exemples de techniques d'analyse comparative.

- Interne ; compare les mesures d'un service ou d'une division avec celles d'autres services ou divisions au sein de la même organisation
- Concurrence / industrie : compare les mesures entre différents concurrents directs ou entreprises similaires.
- Chef de file compare les mesures similaires pour des entreprises de différents secteurs industriels.

Modèles probabilistes

Ces modèles associent une série d'événements et les conséquences qui en résultent, ainsi que la probabilité de ces événements basée sur certaines hypothèses. La probabilité et l'impact sont évalués à partir de données historiques ou de résultats simulés reflétant les hypothèses de comportement futur. Différentes échéances peuvent être utilisées pour évaluer les perspectives. Les modèles probabilistes peuvent également être employés pour évaluer les résultats moyens ou attendus en fonction d'impacts imprévus ou extrêmes. Voici quelques exemples de modèles probabilistes :

- Valeur à risque (VaR) : modèles basés sur des hypothèses de répartition concernant le changement de la valeur d'un élément ou d'un groupe d'éléments qui ne doit pas dépasser un niveau de confiance donné pendant une période donnée. Ces modèles sont utilisés pour évaluer les plages extrêmes de changements de valeur peu fréquents (par exemple, une perte estimée avec un niveau de confiance de 95 %). Le niveau de confiance souhaité et l'échéance sont choisis par la direction et reflètent la tolérance au risque de l'organisation. Exemple estimation du capital requis par une unité d'affaires (avec un niveau de confiance de 99 %) pour couvrir les pertes potentielles pendant une période donnée

Avec une distribution normale, 95% des résultats se situeront à moins de 1,96 écart-type de la moyenne et 99% des résultats se situeront à moins de 2,57 écart-type de la moyenne. Toutefois, la VaR est axée sur le risque lié aux risques d'achat, ce qui signifie que, sur un niveau de confiance de 95%, la principale préoccupation est le risque de 5% que la perte dépasse un montant donné. Par exemple, si la VaR d'un actif est de 100 millions de dollars sur une semaine, avec un niveau de confiance de 95%, il n'y a que 5% de chance que la valeur de l'actif diminue de plus de 100 millions de dollars sur une

semaine donnée. La VaR est exprimée dans l'équation suivante : $VaR = k\sigma\sqrt{N}$ Où k est le niveau de probabilité, σ est l'écart-type et N est la période sur laquelle la VaR est calculée.

Exemple : les flux de trésorerie annuels d'un projet devraient suivre la distribution normale avec une moyenne de 50 000 USD et un écart-type de 10 000 USD. Le projet a une durée de vie de dix ans. Quel est le projet VaR (ou PVar) ?

PVaR pour un an est : PVaR = 1,645 x 10 000 $ x √1 = 16 450 $

Le PVaR qui prend en compte la vie entière du projet est :

PVaR = 1,645 x 10 000 $ x √10 = 52 019 $

Par conséquent, le projet ne devrait pas dépasser 52 019 dollars sur dix ans, avec un niveau de confiance de 95%.

- Flux de trésorerie à risque : Estimation d'un changement au niveau des flux de trésorerie par rapport aux flux de trésorerie prévus, avec un niveau de confiance donné sur une période définie. Repose sur des hypothèses de répartition concernant le comportement des changements affectant les flux de trésorerie. Cette estimation réalisée au niveau de l'entité ou au niveau des unités d'affaires. Exemple un fabricant mesurant les risques de change liés aux flux nets de trésorerie.

- Bénéfice à risque : Estimation d'un changement au niveau des bénéfices comptables d'une organisation ou d'une unité d'affaires qui ne doit pas dépasser un niveau de confiance donné pendant une période définie.

Repose sur des hypothèses de répartition concernant le comportement des changements affectant les bénéfices comptables. Exemple : simulation informatique du chiffre d'affaires à l'aide de la méthode Monte-Carlo afin de garantir un bénéfice donné par action

- Distributions des pertes : Evaluation à l'aide de techniques statistiques des répartitions maximales des créances irrécouvrables ou opérationnelles avec un niveau de confidence donné. Exemple collecte des données sur les pertes opérationnelles classées par cause d'origine (par exemple pratiques de vente], association de ces données aux produits et frais d'assurance correspondants, développement d'une répartition préliminaire des pertes et affinement pour refléter les réponses de l'organisation aux risques.

- Contrôles ex post : Comparaison périodique des mesures à risque d'une entité aux profits ou pertes ultérieurs afin d'évaluer la qualité et la précision des systèmes d'évaluation des risques Exemple : une banque qui compare systématiquement les profits et les pertes quotidiennes aux résultats générés par les modèles de risque.

Modèles non probabilistes

Utilisent des hypothèses subjectives pour évaluer l'impact d'évènements sans quantifier la probabilité associée Basent les évaluations sur des données historiques ou simulées ; et sur des hypothèses de comportement futur. Voici quelques exemples de modèles non probabilistes :

- Analyse de sensibilité : évalue l'impact des changements normaux ou routiniers sur des événements potentiels. Mesure le changement au niveau d'une variable induit par le changement d'une autre variable. Utilisée avec les mesures opérationnelles et les titres de capital en utilisant le bêta.

Exemples les effets des fluctuations du volume des ventes sur le temps de réponse du centre d'appels ou les mouvements d'un seul stock par rapport aux mouvements d'un portefeuille global de marché.

- Analyse de scénario Evalue l'effet d'un ou plusieurs événements sur un objectif. Examine les fluctuations des estimations de rentabilité pour plusieurs jeux d'hypothèses. Permet notamment d1 évaluer les scénarios optimistes, pessimistes et les plus probables, ou les scénarios les plus favorables les plus défavorables ou de base Exemple estimer l'impact d'une panne de réseau dans une entreprise ou le flux net de trésorerie d'un investissement en capital.

- Tests de tension : Évalue l'impact d'événements ayant une incidence extrême. Se concentre sur l'impact direct du changement d'un seul événement ou d'une seule activité dans ces circonstances extrêmes afin d'éviter les surprises et des pertes considérables. Exemples : estimation de I effet d'un mouvement rapide et étendu du taux de change ou d'une augmentation des défauts de fabrication d'un produit.

La modélisation des risques est une méthode d'évaluation et de priorisation des risques. La modélisation des risques classe et valide les priorités de risque lors de la définition des priorités des missions dans le plan d'audit. Les facteurs de risque peuvent être pondérés en fonction de jugements professionnels afin de déterminer leur importance relative, mais les poids n'ont pas besoin d'être quantifiés. Ce modèle simple et le processus d'évaluation des risques qui en résulte peuvent être décrits comme suit :

EXEMPLE

Un chef de l'audit examine la carte des risques suivante à l'échelle de l'entreprise :

		PROBABILITE		
		Eloigné	Possible	Probable
IMPACT	Critique	Risque A	Risque B	
	Majeur			Risque D
	Mineur		Risque C	

Pour établir des priorités quant à l'utilisation de ressources limitées en vérification interne, le RAI fait l'analyse suivante :

- Le risque D a clairement la priorité sur le risque C parce que D a à la fois une plus grande probabilité et un plus grand impact.
- Le risque B a clairement une priorité plus élevée que le risque A car B a une probabilité plus élevée et le même impact.

- Le choix de la priorité la plus élevée entre le risque D et le risque B relève du jugement professionnel fondé sur l'évaluation des risques organisationnels et sur les priorités déclarées de la direction générale et du conseil.
- Si la menace la plus probable est considérée comme le plus grand risque, le risque D se classera plus haut dans le plan de travail de l'audit interne.
- De même, si la menace ayant le plus d'impact possible inquiète davantage la direction et le conseil d'administration, l'activité d'audit interne accordera une plus grande priorité au risque B.

Des canaux de communication ouverts avec la direction générale et le conseil sont nécessaires pour s'assurer que le plan d'audit est fondé sur les évaluations de risques et les priorités d'audit appropriées. Le plan d'audit doit être réévalué si nécessaire.

La modélisation des risques dans un service de conseil est effectuée en classant le potentiel de la mission pour (1) améliorer le management des risques, (2) ajouter de la valeur et (3) améliorer les opérations de l'organisation. La direction générale attribue un poids à chaque élément en fonction des objectifs organisationnels. Les engagements avec les valeurs pondérées appropriées sont inclus dans le plan d'audit annuel.

Étape 4 - Réponse au risque

La réponse aux risques est un sujet de management des risques fréquemment testé. En particulier, avoir une bonne connaissance et compréhension des stratégies de réponse au risque (évitement, acceptation, réduction et partage) et des exemples pour chacune d'entre elles augmentera votre réussite à l'examen.

Les réponses aux risques sont les moyens par lesquels une organisation choisit de gérer les risques individuels. Chaque organisation sélectionne les réponses aux risques qui alignent les risques sur l'appétence pour le risque (le niveau de risque que l'organisation est prête à accepter).

Les stratégies de réponse au risque comprennent les suivantes :

- **L'évitement des risques** met fin à l'activité à l'origine du risque. Par exemple, le risque de sabotage d'un pipeline peut être évité en vendant le pipeline.
- **L'acceptation des risques** accepte le risque d'une activité. Ce terme est synonyme d'auto-assurance.
- **La réduction des risques** (atténuation) réduit le niveau de risque associé à une activité. Par exemple, le risque de pénétration des systèmes peut être réduit en maintenant une fonction efficace de sécurité de l'information au sein de l'entité.
- **Le partage des risques** transfère un certain potentiel de perte à une autre partie. Des exemples sont l'assurance, la couverture, la conclusion de coentreprises, l'externalisation d'une activité et les ententes contractuelles avec des clients, des fournisseurs ou d'autres partenaires commerciaux.

Le risque résiduel est le risque qui subsiste après l'exécution des réponses au risque.

Dans les grandes entités ou les entités complexes, la direction générale peut nommer un comité des risques pour a) examiner les risques identifiés par les diverses unités opérationnelles et b) créer un plan d'intervention. Tout le personnel doit être conscient de l'importance de la réponse au risque appropriée à leurs niveaux de l'entité.

Étape 5 - Surveillance des risques

Le suivi des risques (a) suit les risques identifiés, (b) évalue les plans actuels de réponse aux risques, (c) surveille les risques résiduels et (d) identifie les nouveaux risques.

Les deux sources d'information les plus importantes pour les évaluations continues de l'adéquation des réponses aux risques (et la nature changeante des risques) sont

- Les plus proches des activités. Le gestionnaire d'une unité d'exploitation est le mieux placé pour surveiller les effets des stratégies de réponse au risque choisies.
- La fonction d'audit. Les directeurs d'exploitation peuvent ne pas toujours être objectifs quant aux risques auxquels font face leurs unités, surtout s'ils ont aidé à concevoir une stratégie de réponse particulière. L'analyse des risques et des réponses fait partie des responsabilités normales des auditeurs internes.

3. Responsabilité pour les aspects du management des risques organisationnels

Le management des risques est une responsabilité clé de la direction générale et du conseil.

- La **direction** garantit que les processus de management du risque fonctionnent.
- Les **conseils** ont une fonction de surveillance. Ils déterminent que les processus de management des risques sont en place, adéquats et efficaces.
- **L'activité d'audit interne** peut être destinée à examiner, évaluer, déclarer ou recommander des améliorations. Elle a également un rôle de conseil dans l'identification, l'évaluation et la mise en œuvre de méthodes et de contrôles de management des risques.

La direction générale et le conseil déterminent le rôle de l'activité d'audit interne dans le management des risques en fonction de facteurs tels que (1) la culture de l'organisation, (2) la compétence de l'équipe d'audit interne et (3) les us et coutumes du pays. Ce rôle peut aller :

- Aucun rôle.
- Audit du processus de gestion des risques dans le cadre du plan d'audit interne.
- Fourniture d'informations et de données historiques sur les événements à risque identifiés dans les résultats des audits internes.
- Implication et soutien actifs et continus au processus de gestion des risques, par exemple par le biais d'une participation aux comités de supervision, d'activités de surveillance et du reporting des états.
- Gestion et coordination du processus de management des risques.

Cependant, la responsabilité dans le processus de management des risques, son impact potentiel sur l'indépendance de l'audit interne nécessitent une discussion approfondie et une approbation de la part du Conseil.

Le RAI doit comprendre les attentes de la direction et du conseil à l'égard de l'activité d'audit interne en matière de management des risques. L'entente est codifiée dans les chartes de l'activité d'audit interne et du conseil. Si l'organisation n'a pas de processus formel de management des risques, le RAI a des discussions formelles avec la direction et le conseil sur leurs obligations de compréhension, de gestion et de surveillance des risques.

Les processus de management des risques peuvent être formels ou informels, quantitatifs ou subjectifs, ou intégrés dans des unités commerciales ou centralisés. Ils sont conçus pour s'adapter à la culture, au style de gestion et aux objectifs de l'organisation. Par exemple, une petite entité peut utiliser un comité de risque informel. L'auditeur interne s'assure que la méthodologie retenue est suffisamment exhaustive et adaptée à la nature des activités de l'organisation.

Lors de l'évaluation de l'adéquation et de l'efficacité d'un système quelconque, y compris la gestion des risques, le contrôle interne et la gouvernance, il existe des distinctions entre les termes qu'un auditeur interne doit bien comprendre.

L'***adéquation*** de la gestion des risques, du contrôle et de la gouvernance : Se caractérise par la planification et l'élaboration de ces processus par la direction d'une manière qui garantit la réalisation des objectifs de l'organisation de façon efficace et rentable. Les performances en termes d'efficience permettent d'atteindre les objectifs de façon précise, opportune et économique. Les performances en termes de rentabilité permettent d'atteindre les objectifs en utilisant un minimum de ressources (c'est-à-dire de coûts), en proportion de l'exposition au risque. L'assurance raisonnable est garantie si les mesures les plus rentables sont prises lors des phases de conception et de mise en œuvre pour réduire les risques et limiter les écarts attendus par rapport à un niveau acceptable. Ainsi, le processus de conception commence avec la définition des objectifs. Ensuite, les concepts, les parties, les activités et les personnes seront reliés et rattachés afin qu'ils puissent fonctionner ensemble pour atteindre les objectifs et buts fixés.

L'***efficacité*** de la gestion des risques, du contrôle et de la gouvernance : Existe lorsque la direction exécute les processus de manière à fournir une assurance raisonnable que les objectifs et les buts de l'organisation seront atteints. En plus de réaliser les objectifs et activités prévus, le management autorise des activités et des opérations, effectue un suivi de la performance et des résultats, et vérifie que les processus de l'organisation fonctionnent comme prévu, et ce dans le cadre de ses fonctions.

4. Rôle de l'audit interne dans le management des risques

L'IIA a publié l'Interprétation suivante pour clarifier le rôle de l'audit interne :

Interprétation de la norme 2120 : Déterminer si les processus de management des risques sont efficaces relève du jugement professionnel des auditeurs internes. Pour cela, ils évaluent si :

- Les objectifs de l'organisation sont cohérents avec sa mission et y contribuent ;

- Les risques significatifs sont identifiés et évalués ;
- Les modalités de traitement des risques retenues sont appropriées et en adéquation avec l'appétence pour le risque de l'organisation ;
- Les informations relatives aux risques sont recensées et communiquées en temps opportun au sein de l'organisation pour permettre aux collaborateurs, à leur hiérarchie et au Conseil d'exercer leurs responsabilités.

Pour étayer cette évaluation, l'audit interne peut s'appuyer sur des informations issues de différentes missions.

Une vision consolidée des résultats de ces missions permet une compréhension du processus de management des risques de l'organisation et de son efficacité.

La surveillance du processus de management des risques est effectuée au moyen d'activités courantes de management, d'évaluations distinctes ou par ces deux moyens.

Deux normes de mise en œuvre associent l'évaluation du risque aux zones à risques spécifiques.

Norme de mise en œuvre 2120.A1 : L'audit interne doit évaluer les risques afférents à la gouvernance, aux opérations et aux systèmes d'information de l'organisation au regard de :

- L'atteinte des objectifs stratégiques de l'organisation ;
- La fiabilité et l'intégrité des informations financières et opérationnelles ;
- L'efficacité et l'efficience des opérations et des programmes ;
- La protection des actifs ;
- Le respect des lois, règlements, règles, procédures et contrats.

Norme de mise en œuvre 2120.A2 : L'audit interne doit évaluer la possibilité de fraude et la manière dont ce risque est géré par l'organisation.

Conformément au Guide de mise en œuvre 2120, *Management des risques,* le responsable de l'audit interne et les auditeurs internes cherchent en premier lieu à comprendre l'appétence pour le risque de l'organisation, ses missions et ses objectifs. Il est également important d'avoir une compréhension complète de la stratégie de l'organisation et des risques identifiés par le management.

Les risques peuvent être de nature financière, opérationnelle, légale, réglementaire, ou stratégique. La définition du management des risques dans le glossaire des Normes internationales pour la pratique professionnelle de l'audit interne est également prise en considération, de même que les référentiels et les modèles internationaux de management des risques. De plus, le Guide de mise en œuvre 2100 - Nature du travail peut être utile pour saisir les fondements indispensables de la mise en œuvre de la Norme 2120.

Cette norme charge l'audit interne de l'évaluation de l'efficacité des processus de management des risques, les auditeurs internes devront donc comprendre le contexte de management des risques de l'organisation, et les mesures correctives qui ont été mises en place pour traiter les risques. En préalable à la mise en œuvre de la Norme 2120, il est important de savoir de quelle manière l'organisation identifie, évalue et surveille les risques.

Dans son évaluation des risques, l'audit interne prendra en compte la taille de l'organisation, sa complexité, son cycle de vie, sa maturité, la structure de son actionnariat et son environnement légal et concurrentiel. Des changements récents dans l'environnement de l'organisation (par exemple de nouvelles réglementations, un nouveau manager, une nouvelle structure organisationnelle, de nouveaux processus et de nouveaux produits) peuvent avoir engendré de nouveaux risques. Le responsable de l'audit interne pourra également examiner la maturité des pratiques de management des risques de l'organisation et déterminer dans quelle mesure l'audit interne pourra s'appuyer sur l'évaluation des risques réalisée par le management.

Enfin, l'audit interne devra avoir établi un processus d'audit (planification, réalisation et communication) des problèmes de management des risques. Les auditeurs internes évalueront également le management des risques au cours des missions d'assurance et de conseil d'un domaine ou d'un processus donné.

À travers la mise en œuvre de la Norme 2120, le responsable de l'audit interne et l'ensemble de l'équipe d'audit interne démontreront in fine leur compréhension des processus de management des risques et chercheront des occasions pour les améliorer. En s'entretenant avec la direction générale et le Conseil, le responsable de l'audit interne examinera l'appétence pour le risque, le seuil de tolérance au risque, et la culture du risque de l'organisation. L'audit interne devra alerter le management des nouveaux risques et des risques qui n'ont pas été correctement maîtrisés, proposé des recommandations et des plans d'actions pour répondre de manière appropriée aux risques (par exemple les accepter, les exploiter, les transférer, les maîtriser ou les éviter). De plus, l'audit interne devra obtenir une information suffisante pour évaluer l'efficacité des processus de management des risques de l'organisation.

En analysant le plan stratégique, le business plan et les politiques de l'organisation et en discutant avec le Conseil et la direction générale, le responsable de l'audit interne peut se faire un point de vue lui permettant d'évaluer l'alignement des objectifs stratégiques de l'organisation avec sa mission, sa vision, son appétence pour le risque. Des entretiens avec le management intermédiaire peuvent apporter des éléments supplémentaires à propos de cet alignement au niveau des unités opérationnelles.

Les auditeurs internes examineront attentivement la façon dont l'organisation identifie et traite les risques, et dont elle détermine les risques acceptables. En général, l'audit interne évalue les responsabilités et les processus relatifs aux risques du Conseil ainsi que les principaux rôles en matière de management des risques. A cette fin, les auditeurs internes pourront passer en revue les évaluations des risques récemment effectuées et les communications y afférentes par la direction générale, les auditeurs externes, les régulateurs et d'autres sources.

En outre, l'audit interne conduit généralement ses propres évaluations des risques. Des discussions avec la direction générale et le Conseil et un examen des politiques et des procès-verbaux de l'organisation révéleront généralement son appétence pour le risque, et permettront au responsable de l'audit interne et à la fonction d'audit interne de recommander des modalités de traitement de ces risques. L'audit interne peut envisager de recourir à un référentiel de management des risques ou de contrôle qui existe déjà) pur contribuer à l'identification des risques (par exemple, les référentiels du COSO - Committee of Sponsoring Organizations of the Treadway Commission ou l'ISO 31000).

Pour rester au fait de l'exposition à des risques potentiels et pour s'informer des opportunités éventuelles, l'audit interne pourra également faire des recherches sur les nouvelles évolutions et sur les nouvelles tendances sectorielles, ainsi que sur les processus de surveillance, d'évaluation et de traitement des risques et des opportunités.

En suivant cette approche, les auditeurs internes peuvent effectuer, de manière indépendante, des analyses d'écart afin de déterminer si les risques significatifs sont adéquatement identifiés et évalués, de même l'audit interne est alors en mesure de vérifier le processus d'évaluation des risques par le management. Lors de la revue des processus de management des risques, il est important que les auditeurs internes identifient les risques ainsi que les modalités de traitement y afférent et en discutent. Par exemple, si le management choisit d'accepter un risque, le responsable de l'audit interne devra déterminer si cette décision est appropriée, en fonction de l'appétence pour le risque ou de la stratégie de management des risques de l'organisation. Si le responsable de l'audit interne conclut que le management a accepté un niveau de risque qui pourrait s'avérer inacceptable pour l'organisation, le responsable de l'audit interne doit en discuter avec la direction générale et éventuellement en référer au Conseil, conformément à la Norme 2600 - Communication relative à l'acceptation des risques. Si le management choisit d'employer une stratégie de maîtrise des risques, l'audit interne pourra, le cas échéant, évaluer l'adéquation et la rapidité des mesures de remédiation prises. Cet objectif peut être atteint par l'examen de la conception des dispositifs de contrôle et des tests des procédures de contrôle et de surveillance.

Pour évaluer si les informations pertinentes concernant les risques sont effectivement captées et communiquées en temps opportun dans l'organisation, les auditeurs internes peuvent s'entretenir avec des collaborateurs à différents niveaux et déterminer si les objectifs, les risques significatifs et l'appétence pour le risque de l'organisation sont suffisamment expliqués et compris dans l'organisation. En général, l'audit interne évalue également l'adéquation et la rapidité de la communication par le management des résultats du management des risques. L'audit interne peut analyser des procès-verbaux de réunions du Conseil pour déterminer si les risques significatifs sont communiqués en temps opportun au Conseil et s'il s'assure effectivement que la direction générale les traite de manière appropriée.

In fine, l'audit interne devra prendre les mesures nécessaires pour s'assurer que ses propres risques, tels que les défaillances d'audit, la fausse assurance et les risques de réputation, sont gérés. De même, toutes les mesures correctrices devraient également être suivies.

Parmi les documents qui peuvent démontrer la conformité à la Norme 2120, il y a notamment la Charte d'audit interne qui formalise les rôles et responsabilités de l'audit interne relatifs au management des risques, ainsi que le plan d'audit interne. La conformité peut également être prouvée grâce au contenu des procès-verbaux de réunions entre le responsable de l'audit interne, le Conseil et le direction générale au cours desquelles il a été question de certains aspects de cette norme (tels que les recommandations de l'audit interne en matière de management des risques), ou de réunions entre l'audit interne et les comités, les groupes de travail et les principaux dirigeants concernés.

Les évaluations des risques réalisées par l'audit interne et les plans d'action pour le traitement des risques démontrent sa contribution à l'évaluation et à l'amélioration des processus de management des risques.

Pour se faire une opinion sur l'adéquation des processus de management des risques, l'auditeur interne doit obtenir des preuves suffisantes et appropriées concernant la réalisation des objectifs clés. L'auditeur interne peut considérer ce qui suit :

- Rechercher et analyser des informations sur le secteur d'activité de l'organisation, l'évolution récente et les tendances, ainsi que toute autre source d'information appropriée, afin de déterminer les risques susceptibles d'affecter l'organisation et les procédures de contrôle utilisées pour gérer, suivre et réévaluer ces risques ;
- Examiner les règles de l'entreprise ainsi que les procès-verbaux des délibérations du Conseil et du comité d'audit afin de déterminer les stratégies de l'organisation, son approche du management des risques, son appétence pour le risque et son acceptation des risques ;
- Examiner les rapports d'évaluation des risques précédemment établis par le management, les auditeurs internes ou externes et par tout autre intervenant ;
- Organiser des entretiens avec l'encadrement opérationnel et leur direction afin de déterminer les objectifs de chaque branche d'activité, les risques correspondants, et les mesures de suivi, de contrôle et d'atténuation des risques prises par le management ;
- Recueillir des informations afin d'évaluer, en toute indépendance, l'efficacité du processus de suivi, de communication et d'atténuation des risques, et des activités de contrôle correspondantes ;
- Déterminer si les informations ou rapports relatifs au suivi des risques sont adressés au niveau hiérarchique approprié ;
- Vérifier si les rapports concernant les résultats du management des risques sont diffusés selon des modalités et dans des délais appropriés ;
- S'assurer du caractère exhaustif de l'analyse des risques effectuée par le management et des mesures prises pour résoudre les points soulevés dans le cadre du processus de management des risques, et proposer des améliorations ;

- Apprécier l'efficacité du processus d'auto-évaluation mis en œuvre par le management, au moyen d'observations et de tests sur les procédures de suivi et de contrôle testant l'exactitude des informations utilisées dans le cadre des opérations de suivi, et par d'autres techniques appropriées ;
- Examiner les signes de faiblesse éventuels du dispositif de management des risques et, le cas échéant, les analyser avec la direction générale et le Conseil. S'il estime que le management a accepté un niveau de risques non compatible avec la stratégie et les procédures de l'organisation en matière de management des risques, ou jugé inacceptable pour l'organisation, l'auditeur se réfèrera à la Norme 2600 relative à l'acceptation des risques par le management et aux lignes directives correspondantes pour des orientations complémentaires.

Le rôle de l'audit interne dans le management des risques est précisé ci-dessous :

- L'audit interne doit comprendre (a) la stratégie de l'organisation, (b) comment elle est exécutée, (c) les risques associés, et (d) comment ces risques sont gérés.
- Afin de se concentrer sur les risques critiques, la stratégie devrait constituer une base fondamentale pour un plan d'audit axé sur les risques qui a) aligne l'audit interne sur les priorités stratégiques et b) contribue à assurer l'affectation des ressources aux domaines d'importance significative.
- Pour élaborer le plan d'audit, l'audit interne doit utiliser le travail de la direction et d'autres fonctions d'assurance pour aider à identifier les risques qui constituent les menaces les plus importantes et les opportunités pour atteindre les objectifs stratégiques. L'audit interne devrait envisager de fournir des services d'assurance liés aux initiatives stratégiques. Le but est d'évaluer si les risques stratégiques sont gérés à un niveau acceptable en évaluant tout ou partie des efforts d'atténuation. L'audit interne peut également fournir des services de conseil qui affectent directement l'évolution de l'organisation.
- Après avoir déterminé les risques stratégiques à inclure dans le plan d'audit, l'audit interne doit évaluer s'il possède les compétences et les connaissances requises pour exécuter les missions d'assurance ou de conseil appropriées. Les compétences et connaissances spécialisées peuvent devoir être sous-traitées ou externalisées pour obtenir les qualifications requises.

Trois normes de mise en œuvre traitent des responsabilités des vérificateurs internes en matière de gestion des risques lorsqu'ils effectuent des missions de conseil.

Norme de mise en œuvre 2120.C1 – Au cours des missions de conseil, les auditeurs internes doivent couvrir les risques liés aux objectifs de la mission et demeurer vigilants vis-à-vis de l'existence de tout autre risque susceptible d'être significatif.

Norme de mise en œuvre 2120.C2 – Les auditeurs internes doivent utiliser leurs connaissances des risques acquises lors de missions de conseil, pour évaluer les processus de management des risques de l'organisation.

Norme de mise en œuvre 2120.C3 - Lorsque les auditeurs internes accompagnent le management dans la conception et l'amélioration des processus de management des risques, ils doivent s'abstenir d'assumer une responsabilité opérationnelle en la matière.

« The Role of Internal Auditing in Enterprise-wide Risk Management » (Le Rôle de l'audit interne dans le management des risques de l'entreprise) identifie les fonctions que l'audit interne ne doit pas assumer :

- Définir l'appétence pour le risque.
- Imposer des processus de gestion des risques.
- Assurer la gestion des risques.
- Prendre des décisions concernant les réponses aux risques. Mettre en œuvre les réponses aux risques au nom de la direction Être responsable en matière de gestion des risques.

Acceptation du risque par la direction

L'activité d'audit interne évalue l'efficacité des processus de gestion des risques organisationnels à travers ses missions d'assurance et préconise des mesures d'amélioration au comité d'audit et au conseil. Lors de l'évaluation des processus internes, l'activité d'audit interne assure de manière raisonnable que les processus en place vont permettre à l'organisation d'atténuer les risques et d'atteindre ses objectifs de façon efficiente et rentable.

La Norme de fonctionnement 2600 « Communication relative à l'acceptation des risques » stipule : « Lorsque le responsable de l'audit interne conclut que le management a accepté un niveau de risque qui pourrait s'avérer inacceptable pour l'organisation, il doit examiner la question avec la direction générale. Si le responsable de l'audit interne estime que le problème n'a pas été résolu, il doit soumettre la question au Conseil ».

L'interprétation de la norme 2600 clarifie la façon dont les risques peuvent être identifiés et qui est responsable de la gestion de ce risque : « L'identification du niveau de risque accepté par le management peut résulter d'une mission d'assurance, d'une mission de conseil, du suivi des plans d'actions du management à la suite de missions d'audit interne antérieures, ou d'autres moyens. La réponse au risque ne relève pas du responsable d'audit interne. »

La responsabilité de l'acceptation du risque est également traitée dans la Guide de mise en œuvre 2060, « Communication avec la direction générale et le conseil » : « Les communications du responsable de l'audit interne ont pour finalité première d'apporter une assurance et des conseils à la direction générale et au Conseil en ce qui concerne les processus de gouvernance (Norme 2110), de management des risques (Norme 2120) et de contrôle (Norme 2130) de l'organisation… Si le responsable de l'audit interne estime que la direction générale a accepté un niveau de risque qui pourrait s'avérer inacceptable pour l'organisation, il devrait en discuter avec elle. S'ils ne

parviennent pas à s'entendre, la Norme 2600 requiert que le responsable de l'audit interne informe le Conseil. Lorsque la situation ne peut pas attendre la prochaine réunion du Conseil (un cas de fraude majeur par exemple), le responsable de l'audit interne devrait en faire part au plus tôt. »

Risques imprévus

Les plans de mission d'audit hiérarchisent les missions selon plusieurs facteurs, notamment l'utilisation efficace des ressources, les priorités des risques et l'importance des risques et de l'exposition. Le rapport final de l'activité d'audit présente les résultats et les observations. Toutefois, des risques imprévus, c'est-à-dire en dehors de ceux pris en compte lors de la phase de planification des missions fondée sur les risques, apparaissent fréquemment. Voici quelques-uns des nombreux risques possibles :

- Actions en justice
- Problèmes de responsabilité pour les produits/services
- Méfaits de la part d'employés
- Accidents
- Vandalisme
- Sabotage
- Erreurs commises par des employés
- Erreurs commises par des fournisseurs
- Arriérés de comptes fournisseurs
- Rendement d'investissements financiers inacceptable
- Délais de récupération de projets inacceptables
- Catastrophes naturelles
- Départ, décès ou handicap inattendu d'un membre clé de l'organisation
- Contrôles inadaptés
- Fraude

En réalité, même les processus de gestion des risques les plus efficients et efficaces ne peuvent pas prévoir tous les risques potentiels. Si des risques imprévus se présentent et que le RAI les juge important, celui-ci doit discuter des expositions au risque avec le comité d'audit et le conseil.

II. GESTION DES RISQUES DE L'ENTREPRISE

1. Le cadre COSO ERM

Gestion du risque d'entreprise - Intégration à la stratégie et au rendement (cadre de GRE du COSO) est un cadre qui complète et intègre certains concepts du cadre de contrôle interne du COSO.

Le cadre de COSO ERM fournit une base pour coordonner et intégrer toutes les activités de gestion des risques d'une organisation. Une intégration efficace (1) améliore la **prise de décision** et (2) améliore le **rendement**.

2. Définition et Concepts ERM

La GRE repose sur la prémisse que chaque organisation existe pour offrir de la **valeur** à ses parties prenantes. Par conséquent, la GRE se définit comme suit :

Le management des risques d'entreprise est un processus appliqué par le conseil d'administration, *la direction et le personnel d'une entité, appliqué dans la stratégie, ainsi que dans toutes les activités de l'organisation, conçu pour identifier les événements susceptibles d'affecter l'entité et gérer le risque dans son appétence pour le risque, pour fournir une assurance raisonnable quant à la réalisation des objectifs de l'entité.*

Concepts et expressions clés.

1) **La culture** consiste en " les attitudes, les comportements et la compréhension du **risque**, tant positifs que négatifs, qui influencent les décisions de la direction et du personnel et reflètent la mission, la vision et les valeurs fondamentales de l'organisation.

- **La mission est l'**objectif principal de l'organisation.
- **La vision** est l'aspiration de l'organisation à ce qu'elle a l'intention de réaliser au fil du temps.
- **Les valeurs fondamentales** sont les croyances essentielles de l'organisation quant à ce qui est acceptable ou inacceptable.

2) **Les capacités** sont les compétences nécessaires à la réalisation de la mission et de la vision de l'entité.

3) **Les pratiques** sont les méthodes collectives utilisées pour gérer les risques.

4) **Intégrer l'élaboration de la stratégie et la performance.** Le risque doit être pris en compte dans l'établissement de la stratégie, des objectifs opérationnels, des cibles de rendement et de la tolérance.

- **La stratégie** communique la façon dont l'organisation (a) réalisera sa mission et sa vision et (b) appliquera ses valeurs fondamentales.
- **Les objectifs opérationnels** sont les mesures prises pour réaliser la stratégie.
- **La tolérance** est la plage de variation acceptable des résultats de performance. (Ce terme est identique à celui de "tolérance au risque" dans le cadre de contrôle interne du COSO.)

L'organisation tient compte de l'effet de la stratégie sur son profil de risque et sa vision du portefeuille.

- **Le profil de risque** est une vue composite des types, de la gravité et de l'interdépendance des **risques** liés à une stratégie ou à un objectif commercial précis et de leur effet sur le **rendement**. Un profil de risque peut être créé à n'importe quel niveau (p. ex., entité,

division, unité opérationnelle ou fonction) ou aspect (p. ex., produit, service ou région géographique) de l'organisation.

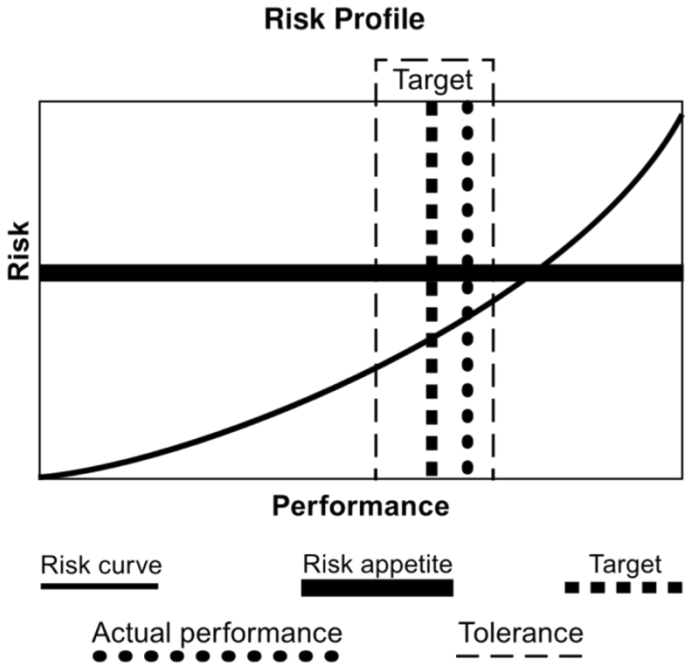


Figure 4-1

- **La vue du portefeuille** est similaire à un profil de risque. La différence réside dans le fait qu'il s'agit d'une vue composite des risques liés à la stratégie et aux objectifs commerciaux de l'**entité** et de leurs effets sur la performance de **l'entité.**

5) **Gérer les risques.**

- Le **risque** est la possibilité qu'un événement se produise et affecte négativement la réalisation des objectifs.
- Une **opportunité** est la possibilité qu'un événement se produise et affecte positivement la réalisation des objectifs en créant ou en préservant de la valeur. La direction prévoit exploiter les opportunités, sous réserve des objectifs et des stratégies de l'entité.
- Le **risque inhérent** est le risque en l'absence de mesures de gestion visant à en modifier la gravité.
- Le **risque résiduel réel** demeure après que la direction a pris des mesures pour en modifier la gravité.
- **La réponse au risque** est une mesure prise pour que les risques cernés fassent partie de l'appétit de l'organisation pour le risque.
- Le **risque de contrôle** est le risque que les contrôles ne parviennent pas à gérer efficacement les risques contrôlables.
- Le **risque résiduel** est le risque qui subsiste après une réponse au risque.
- **L'appétence pour le risque** est le niveau de risque qu'une entité est prête à accepter en quête de valeur. Elle reflète la philosophie de management des risques de l'entité et influe sur la culture et le style d'exploitation de l'entité.

- La **tolérance au risque** est la variation acceptable par rapport à la réalisation d'un objectif.
- Un **profil de risque résiduel** comprend les réactions aux risques.
- **Le risque résiduel cible** est le risque que l'entité préfère assumer en sachant que la direction a agi ou agira pour en modifier la gravité.

6) **La valeur** est

- **Créée** lorsque les bénéfices tirés des ressources utilisées dépassent leurs coûts.
- **Préservée** lorsque la valeur des ressources utilisées est maintenue.
- **Réalisée** lorsque les avantages sont transférés aux parties prenantes.
- **Érodée** lorsque la stratégie de gestion ne produit pas les résultats escomptés ou lorsque la gestion ne s'acquitte pas des tâches quotidiennes.

3. Rôles et responsabilités

La gestion des risques inclut un large éventail d'activités destinées à identifier, évaluer, gérer et contrôler les risques à travers toute l'entreprise, des événements ou projets ponctuels à des types de risque précis (p. ex. risque du marché), en passant par les menaces qui pèsent sur l'entreprise et les possibilités qui lui sont offertes.

Traditionnellement, les responsabilités en matière de gestion des risques sont confiées à chaque unité d'affaires et/ou à des sections des unités d'affaires. La gestion des risques était théoriquement considérée comme une initiative de l'organisation. Mais en pratique, les activités de gestion des risques se répartissaient rarement à travers l'organisation.

Comme nous l'avons vu, pour que la gestion des risques soit efficace, chaque membre de l'organisation, quel que soit son niveau, doit prendre part au processus. Produire des informations utilisables pour identifier les risques, prendre les mesures nécessaires pour mener à bien la gestion des risques, et soutenir les flux de communication et d'informations sont des tâches qui entrent implicitement et explicitement dans la description de chaque poste. Toutefois, le COSO indique que des rôles et des responsabilités particulières incombent au conseil, à la direction, aux directeurs des risques, aux directeurs financiers, aux auditeurs internes et à certaines parties externes. Nous allons à présent examiner ces groupes et ces individus.

Conseil d'administration. Le conseil, ou son équivalent, sert plusieurs fonctions. Le conseil est responsable une culture de la surveillance des risques, des capacités et des pratiques de GRE. Souvent, le conseil délègue à la direction ses responsabilités en matière de surveillance et d'assurance, et se réserve toute l'autorité sur les décisions clés.

Le COSO décrit la supervision du management des risques de l'entreprise par le conseil de la manière suivante :

- Connaître l'étendue et l'efficacité du management des risques de l'entreprise établi dans l'organisation par la direction.
- Connaître l'appétence de l'entité pour le risque et s'aligner sur celui-ci.

- Examiner la vue globale de l'entité sur le risque et évaluer celui-ci par rapport à l'appétence de l'entité pour le risque.
- Connaître les risques les plus significatifs et s'assurer que la direction y répond de façon adéquate.

Le conseil d'administration fait partie de la composante gouvernance et culture du modèle COSO. Par son action, il établit un précédent aux valeurs éthiques et d'intégrité. Le conseil peut utiliser des ressources pour mener des enquêtes particulières et peut recourir à des comités pour exécuter certaines tâches. À un comité sur les rémunérations, par exemple, incomberaient les responsabilités relatives à divers aspects du système de récompense. Autre exemple : le comité d'audit pourrait être chargé de superviser la fiabilité du reporting externe. En résumé, les décisions, l'engagement, les objectifs et les activités du conseil influent fortement sur la gestion des risques à un niveau acceptable.

La direction. La direction est le principal responsable de l'identification, de l'évaluation et de la gestion des risques, ainsi que de la mise en œuvre du management des risques de l'entreprise selon une approche structurée, cohérente et coordonnée. Les responsabilités propres aux directeurs de chaque niveau varient d'une organisation à l'autre.

S'il existe plusieurs niveaux de gestion, les gestionnaires de sous-unités ou le personnel de supervision de niveau inférieur peuvent être directement impliqués dans l'exécution des politiques et procédures à un niveau détaillé. La hiérarchie de gestion pourrait être structurée en utilisant ce que l'on appelle les « trois lignes de défense », qui ont une condition préalable à la surveillance de la gestion des risques et à la définition de la stratégie par le conseil d'administration et la haute direction. (Ni le conseil d'administration ni la haute direction ne font partie des trois lignes de défense en soi.) Les trois lignes de défense sont les suivantes :

- **Première ligne - gestion opérationnelle**. Des managers opérationnels chargés d'identifier et de gérer les performances et les risques inhérents à la stratégie et à la réalisation des objectifs de l'entreprise ainsi que de sélectionner et de gérer les contrôles de gestion et les mesures de contrôle interne. Ce sont les fonctions opérationnelles qui possèdent et gèrent les risques.
- **Deuxième ligne - fonctions de gestion des risques et de conformité**. Domaines fonctionnels ou individus chargés de fournir des conseils sur les exigences de performance et de GRE et d'évaluer le respect des réglementations et normes définies. Cela comprend les postes de contrôleur financier pour les risques financiers. Ces fonctions existent pour garantir que la première ligne de défense est en place et fonctionne correctement ; par conséquent, ils ont besoin d'une certaine indépendance par rapport à la première ligne. Cependant, parce qu'ils sont managers ou qu'ils travaillent sous la direction management, ils ne peuvent pas avoir une véritable indépendance. La direction de deuxième ligne a un rôle actif dans l'évaluation et la mise en œuvre des cadres de GRE et de contrôle interne, l'identification des risques émergents, le reporting, l'aide à guider les changements d'appétit

pour le risque, et la modification et l'amélioration continue des systèmes de gestion des risques et de contrôle interne.

- **Troisième ligne - audit interne (ou autres fonctions d'assurance)**. Fonctionne conformément aux normes et maintient le plus haut niveau d'indépendance et d'objectivité au sein de l'organisation. Cette ligne de défense assure la responsabilité en réalisant des assurances liées à la gouvernance, à la GRE et aux contrôles internes, y compris les cadres et les pratiques, en identifiant les recommandations, et tenir le conseil et la direction à jour sur les questions nécessitant une résolution.

Voir le document de position de l'IIA « Les trois lignes de défense pour une gestion et un contrôle efficaces des risques » (janvier 2013) pour plus d'informations.

La direction et le conseil travaillent ensemble dans le cadre de la mise en place du processus de stratégie afin de déterminer l'appétence pour le risque de l'organisation. Le COSO définit l'appétence pour le risque comme « le niveau de prise de risque accepté par l'organisation dans le but d'accroître sa valeur ».

L'environnement d'exploitation de l'organisation détermine en partie son appétence pour le risque. Par exemple, l'environnement d'exploitation de sociétés pharmaceutiques nécessite de protéger la valeur de la marque et de minimiser les risques en investissant dans la recherche précoce et les essais. Cependant, une organisation comme celle-ci peut choisir de suivre une stratégie qui l'expose à plus ou moins de risques, comme par exemple prendre la décision d'entrer sur un nouveau marché ou de rester sur des marchés matures plus stables. Le rôle des auditeurs internes est d'assurer que l'organisation a une tolérance suffisante aux risques ou la capacité à absorber les variations au niveau des objectifs, pour tenir compte de l'attribution des ressources au sein de l'organisation et des choix stratégiques liés à l'appétence pour le risque.

Toutefois, la règle universellement suivie est de confier au directeur général la responsabilité finale du processus de management des risques de l'entreprise, de définir « l'implication de la direction » et de garantir un environnement interne positif.

Le COSO présente les responsabilités du directeur général :

- Fourniture d'un encadrement et d'une orientation aux membres de la direction.
- Surveillance des activités et des risques liés à l'appétence pour le risque de l'organisation.
- Maintenir une surveillance des risques auxquels l'organisation est confrontée.
- Guider le développement et la performance des processus de GRE dans toute l'organisation et déléguer à la direction.
- Communiquer les attentes et les besoins d'information.

Les membres de la direction convertissent les stratégies de gestion des risques en opérations. Les responsables de processus, de fonctions ou de services particuliers jouent un rôle à la fois tactique et pratique quant à l'élaboration et à l'exécution des procédures spécifiques de gestion des risques.

Ils tiennent informés leurs supérieurs de l'avancée de leurs activités et recommandent des améliorations.

L'autorité et la responsabilité de la direction sont impératives pour un management des risques de l'entreprise efficace. Chaque directeur doit être responsable devant son supérieur direct, le directeur général étant responsable devant le conseil.

Responsable de la gestion des risques. Dans certaines organisations, un responsable de la gestion des risques, également appelé gestionnaire des risques ou directeur des risques, centralise la coordination de la gestion des risques de l'entreprise à travers toute l'organisation. Nommé par le directeur général, le directeur des risques dispose des ressources nécessaires pour travailler avec d'autres responsables dans le but de développer des pratiques efficaces de gestion des risques, de suivre les progrès et de les assister lors du reporting.

Le COSO répertorie les responsabilités spécifiques du directeur des risques en matière de management des risques de l'entreprise :

- Aider le conseil d'administration et la direction à s'acquitter de leurs responsabilités de surveillance des risques.
- Élaboration des politiques pertinentes et des pratiques continues.
- Établir et maintenir des relations avec ceux qui gèrent les risques organisationnels.
- Encadrement de l'autorité et de la responsabilité dans les unités d'affaires.
- Revoir le fonctionnement de la GRE dans chaque unité commerciale.
- Communiquer à la direction l'état de la gestion des risques d'entreprise, y compris les risques graves et émergents.
- Évolution des capacités organisationnelles en fonction de la pertinence et de la maturité de la GRE.
- Transmission de l'avancée des activités au directeur général, ainsi que des actions recommandées.

Certaines organisations nomment une personne au poste de directeur des risques. D'autres attribuent les responsabilités en matière de management des risques de l'entreprise au directeur financier, à l'avocat conseil ou à un autre cadre supérieur. Un responsable des risques peut également coordonner ses activités avec l'activité d'audit interne.

Directeurs financiers. Les activités financières et de contrôle financier touchent toutes les unités d'exploitation et d'affaires. La budgétisation, la planification financière, le suivi et l'analyse des performances, et le reporting relèvent du champ d'action du directeur financier, du chef du service comptable, du contrôleur ou d'autres individus exerçant une fonction financière. Ces personnes et les activités qu'elles exercent constituent une pièce maîtresse de l'exécution de la gestion des risques par la direction.

Parties externes. Plusieurs parties externes prennent part aux objectifs et aux activités de gestion des risques de l'entreprise d'une entité :

- **Auditeurs externes**. Les auditeurs externes offrent une vision indépendante et objective qui contribue à la réalisation des objectifs de l'entreprise, notamment en termes de reporting financier externe. Bien que la plupart des audits d'états financiers ne s'occupent que peu du management des risques de l'entreprise, le COSO souligne que les informations fournies peuvent aider la direction à prendre en charge ses responsabilités en matière de gestion des risques. Les résultats des audits, les informations analytiques et les actions préconisées sont des données pertinentes pour la réalisation des objectifs définis. Si un audit externe met au jour des insuffisances au niveau de la gestion des risques et du contrôle, l'auditeur peut également communiquer ces informations accompagnées de recommandations d'amélioration. Si la loi ou les règlements (par exemple la loi Sarbanes-Oxley) exigent que l'audit externe évalue le contrôle interne du reporting financier d'une entité, le périmètre de l'audit dans ces domaines est plus rigoureux.

- **Législateurs et régulateurs**. Un grand nombre de lois et de règlements ont une incidence sur le management des risques de l'entreprise d'entités particulières. Les législateurs et les régulateurs établissent des règles qui obligent les systèmes de contrôle et de gestion des risques d'une entité à satisfaire à des exigences légales et réglementaires minimales. Lorsque les organismes de régulation examinent une entité (par exemple lorsque des contrôleurs de banques fédérales et nationales examinent les opérations d'une banque), l'organisation tire généralement des informations utiles sur l'application du management des risques de l'entreprise et des recommandations et/ou des directives portant sur les améliorations nécessaires.

- **Les partenaires**. Les partenaires d'une entité (clients, fournisseurs, créanciers, etc.) peuvent s'avérer des canaux d'informations utiles aux activités de gestion des risques. Les éléments tels que les demandes de nouveaux produits et services, les problèmes de contrôle qualité, les préoccupations éthiques, et les différences entre la facturation et l'expédition peuvent être des informations pratiques pour atteindre les objectifs stratégiques, opérationnels, de reporting ou de conformité.

- **Sous-traitants**. De nombreuses organisations choisissent de sous-traiter certaines activités quotidiennes (paie, comptabilité ou informatique) dans le but de consacrer leurs activités et leurs ressources aux compétences fondamentales de l'organisation. La sous-traitance permet généralement à une organisation de capitaliser sur les compétences d'autres entreprises jugées plus efficaces ou plus expertes dans des tâches spécialisées annexes aux compétences fondamentales de l'organisation. Le COSO affirme le principe selon lequel la direction ne peut pas déléguer à ces fournisseurs externes les activités de gestion des risques associées. Des programmes doivent être élaborés et mis en œuvre pour surveiller ces activités.

- **Analystes financiers, agences de notation et médias d'information**. Les analystes financiers et les agences de notation évaluent un large éventail de facteurs pour émettre un avis sur la santé d'une organisation et sa valeur en tant qu'investissement. Les médias

financiers conduisent fréquemment des analyses similaires. Les observations et les perspectives que ces groupes émettent peuvent s'avérer utiles à la direction afin d'améliorer les activités de gestion des risques.

Pour plus d'informations sur la gestion des risques d'entreprise de COSO - Intégration à la stratégie et aux performances, consultez le site Web de COSO à l'adresse www.coso.org.

4. Composants ERM

Gestion du risque d'entreprise

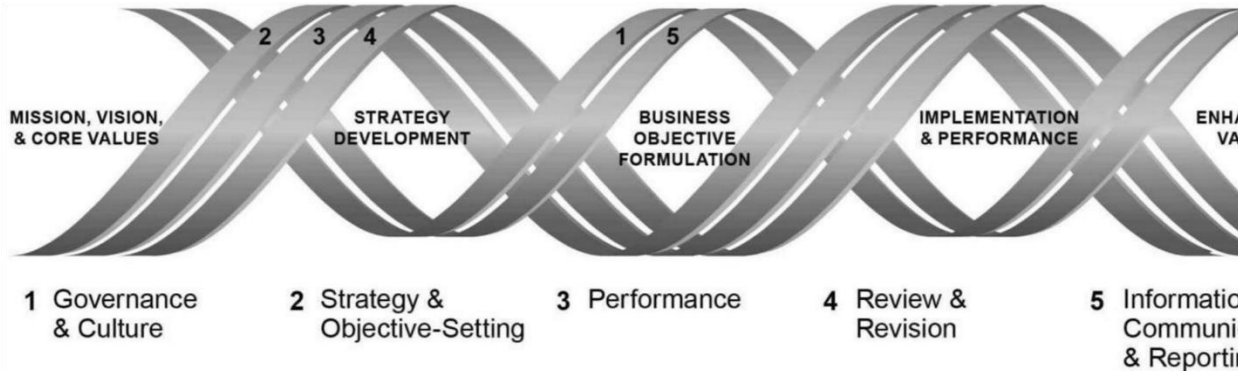


Figure 4-2

Le cadre de GRE du COSO comprend **cinq composantes inter-reliées**. Vingt principes sont répartis entre les composantes.

- Les éléments d'**appui** sont les suivants
  - ✓ Gouvernance et culture et
  - ✓ Information, communication et reporting.
- Les éléments **communs du processus** sont les suivants
  - ✓ Stratégie et fixation d'objectifs,
  - ✓ Rendement, et
  - ✓ Examen et révision.

5. Gouvernance et culture

La gouvernance donne le ton à l'organisation et établit les responsabilités en matière de GRE. La culture est liée aux comportements, aux valeurs et à la compréhension globale du risque que présente le personnel au sein de l'organisation. **Cinq principes** ont trait à la gouvernance et à la culture :

i *Le **conseil** exerce une **surveillance des** risques*.

- L'ensemble du conseil est habituellement responsable de la surveillance des risques. Toutefois, le conseil peut déléguer la surveillance des risques à un comité du conseil, tel qu'un **comité des risques**.

- ✓ **La direction** est généralement responsable au jour le jour de la gestion du rendement et des risques pris pour atteindre les objectifs stratégiques et commerciaux.

- Le rôle de surveillance du conseil d'administration peut comprendre, sans toutefois s'y limiter,
  - ✓ Examiner et remettre en question les décisions liées à la stratégie, à l'appétit pour le risque et aux décisions commerciales importantes (p. ex., fusions et acquisitions).
  - ✓ Approuver la rémunération de la direction.
  - ✓ Participer aux relations avec les parties prenantes.
- La surveillance des risques est plus efficace lorsque le conseil d'administration
  - ✓ Possède les **compétences, l'expérience et les connaissances commerciales** nécessaires pour (a) comprendre la stratégie et le secteur de l'organisation et (b) maintenir cette compréhension à mesure que le contexte commercial évolue.
  - ✓ Est **indépendant** de l'organisation.
  - ✓ Détermine si les capacités et les pratiques de gestion globale des risques augmentent la valeur.
  - ✓ Comprend les **biais organisationnels** (par exemple, une tendance à l'évitement excessif des risques ou à la prise de risques) qui influent sur la prise de décision et met au défi la gestion pour les minimiser.

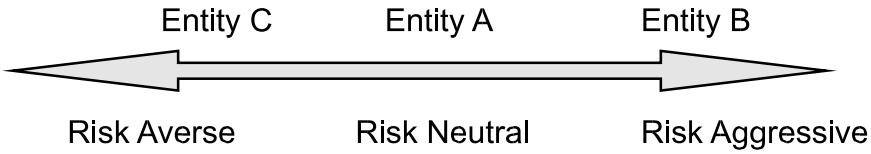
ii *L'organisme établit les **structures opérationnelles**.*

- Ils décrivent la façon dont l'entité est organisée et mène ses activités quotidiennes.
- Elles sont généralement alignées sur la structure juridique et la structure de gestion de l'entité.
  - ✓ La **structure juridique** détermine le mode de fonctionnement de l'entité (**par** exemple, en tant qu'entité juridique unique ou en tant qu'entités juridiques multiples et distinctes).
  - ✓ La **structure de gestion** établit les liens hiérarchiques (p. ex. rapports hiérarchiques directs ou rapports secondaires), les rôles et les **responsabilités**. La direction est responsable de définir clairement les rôles et les responsabilités.
- Les facteurs à prendre en compte lors de l'établissement et de l'évaluation des structures d'exploitation comprennent les suivants :
  - ✓ Stratégie et objectifs commerciaux, y compris les risques connexes.
  - ✓ Nature, taille et répartition géographique.
  - ✓ **Attribution** de l'autorité, de la responsabilité et de l'obligation de rendre compte à tous les niveaux.

- ✓ **Types** de voies hiérarchiques et de canaux de communication.
- ✓ Exigences en matière de rapports (p. ex. financiers, fiscaux, réglementaires et contractuels).

iii *L'organisation définit la **culture** souhaitée*.

- Le conseil d'administration et la direction sont responsables de la définition de la culture.
- La culture est façonnée par des facteurs internes et externes.
  - ✓ **Les** facteurs **internes** comprennent (a) le niveau de jugement et d'autonomie accordé au personnel, (b) les normes et règles, et (c) le système de récompense en place.
  - ✓ Les facteurs **externes** comprennent (a) les exigences légales et (b) les **attentes** des parties prenantes (p. ex. clients et investisseurs).
- La définition de la culture de l'organisation détermine son positionnement dans le spectre de la culture, qui va de l'aversion au risque à l'agressivité.



iv *L'organisation démontre son engagement envers les valeurs fondamentales*.

- Les valeurs fondamentales de l'organisation doivent être reflétées dans toutes ses actions et décisions.
- Le **ton de l'organisation** est la manière dont les valeurs fondamentales sont communiquées à travers l'organisation.
- Lorsque la culture au risque et le ton sont alignés, les parties prenantes ont confiance que l'organisation respecte ses valeurs fondamentales.

v *L'organisation **attire**, **perfectionne** et **maintien en poste des** personnes compétentes*.

- La direction est responsable de définir le capital humain nécessaire (les compétences requises) pour atteindre les objectifs stratégiques et commerciaux.
- La **fonction des ressources humaines** aide la direction à élaborer les exigences en matière de compétences au moyen de processus qui attirent, forment, encadrent, évaluent, récompensent et retiennent des personnes compétentes.
- **Des plans d'urgence** devraient être élaborés pour préparer la relève. Ces plans forment le personnel sélectionné à assumer des responsabilités vitales pour la GRE. Un exemple est la formation d'un gestionnaire des risques pour qu'il assume le poste d'agent des risques.

6. Établissement de stratégies et d'objectifs

La stratégie doit appuyer la mission, la vision et les valeurs fondamentales de l'organisation. L'intégration de la GRE à l'établissement de la stratégie aide à comprendre le profil de risque lié à la stratégie et aux objectifs opérationnels. **Quatre principes** ont trait à la stratégie et à l'établissement des objectifs :

i *L'organisation analyse le **contexte commercial** et son incidence sur le profil de risque*.

- Le contexte commercial se rapporte aux relations, aux événements, aux tendances et aux autres facteurs qui influencent la stratégie et les objectifs commerciaux de l'organisation. Par conséquent, le contexte opérationnel comprend les environnements interne et externe de l'organisation.
  - ✓ **L'environnement interne** est constitué de facteurs liés à quatre catégories : (a) capital (actifs), (b) personnes (compétences et attitudes), (c) processus (tâches, politiques et procédures) et (d) technologie (par exemple, technologie adoptée).
  - ✓ **L'environnement externe** est constitué de facteurs liés aux six catégories suivantes : (a) politique (intervention et influence du gouvernement), (b) économique (par exemple, taux d'intérêt et disponibilité de crédit), (c) sociale (par exemple, préférences des consommateurs et données démographiques), (d) activités technologiques (par exemple, activités de R & D), (e) légales (lois, réglementations et normes de l'industrie) et (f) environnementales (par exemple, changements climatiques).
- Le contexte commercial peut être :
  - ✓ **Dynamique. Des** risques nouveaux, émergents et changeants peuvent apparaître à tout moment (p. ex. de faibles barrières à l'entrée permettent l'apparition de nouveaux concurrents).
  - ✓ **Complexe.** Un contexte peut avoir de nombreuses interdépendances et interconnexions (par exemple, une société transnationale a plusieurs unités opérationnelles dans le monde, chacune ayant des facteurs environnementaux externes uniques).
  - ✓ **Imprévisible. Le** changement se produit rapidement et de façon imprévue (p. ex. fluctuations monétaires).
- L'effet du contexte commercial sur le profil de risque peut être analysé en fonction du rendement passé, présent et futur.

ii *L'organisation définit l'**appétit pour le risque** (le degré de risque qu'elle est prête à accepter en quête de valeur)*.

- L'organisation tient compte de sa mission, de sa vision, de sa culture, de ses stratégies antérieures et de sa capacité de risque (le risque maximal qu'elle peut assumer) pour déterminer son l'appétit pour le risque.
- Dans l'établissement de l'appétit pour le risque, on cherche l'équilibre optimal entre les possibilités et les risques.

- ✓ L'appétit pour le risque est rarement supérieur à la capacité de risque.

- L'appétit pour le risque peut être exprimé **de façon qualitative** (p. ex. faible, modérée, élevée) ou **quantitative** (p. ex. en pourcentage d'un montant financier). Mais elle devrait refléter la façon dont les résultats de l'évaluation des risques sont exprimés.
- Le conseil approuve l'appétit pour le risque et la direction le communique à l'ensemble de l'organisation.

iii *L'organisation évalue les **stratégies alternatives** et leurs effets sur le profil de risque*.

- Les approches d'évaluation de la stratégie comprennent l'analyse SWOT (forces – faiblesses - opportunités - menaces), analyse des concurrents et analyse de scénarios.
- L'organisation doit évaluer :
  - ✓ L'harmonisation de la stratégie avec sa mission, sa vision, ses valeurs fondamentales et son appétit pour le risque.
  - ✓ Les implications de la stratégie choisie (ses risques, ses opportunités et ses effets sur le profil de risque).
- La stratégie doit être modifiée si elle ne parvient pas à créer, réaliser ou préserver de la valeur.

iv *L'organisation établit des **objectifs opérationnels** qui s'harmonisent avec la stratégie et la soutiennent*.

- Les objectifs d'affaires sont (1) spécifiques, (2) mesurables, (3) observables et (4) réalisables.
- Les objectifs d'affaires peuvent porter, entre autres, sur le rendement financier, l'excellence opérationnelle ou les obligations de conformité.
- Des mesures de rendement, des cibles et des tolérances (la fourchette de variation acceptable du rendement) sont établies pour évaluer l'atteinte des objectifs.

7. Performance

Le rendement est lié aux pratiques de GRE qui appuient les décisions de l'organisation en matière de recherche de valeur. Ces pratiques consistent à identifier, évaluer, classer par ordre de priorité, réagir aux risques et développer une vision du portefeuille. **Cinq principes** ont trait au rendement :

i *L'organisation **détermine les risques** qui influent sur le rendement de la stratégie et des objectifs opérationnels*.

- L'organisation devrait cerner les risques qui perturbent les activités et influent sur les **attentes raisonnables quant à l'**atteinte des objectifs stratégiques et opérationnels.
- Les risques **nouveaux**, **émergents** et **changeants** sont identifiés. Il s'agit, par exemple, des risques résultant de changements dans les objectifs ou le contexte de l'entreprise.

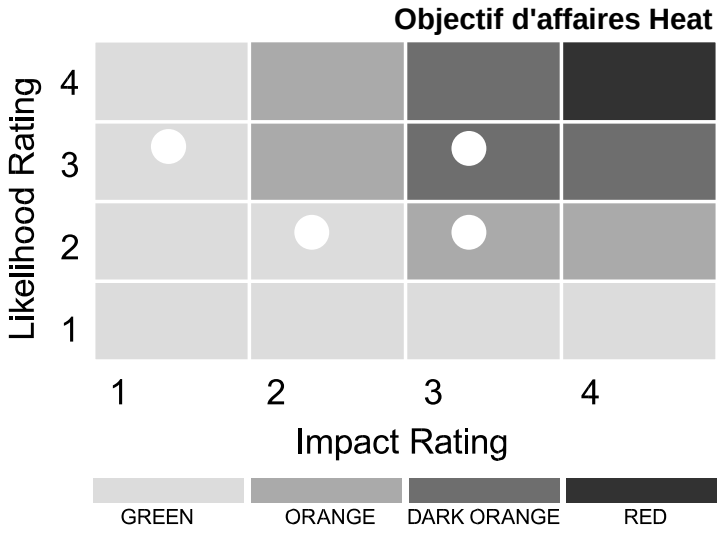
- ✓ L'organisation détermine également les **possibilités**. Il s'agit d'actions ou d'actions potentielles qui créent ou modifient des objectifs ou des approches pour la création, la préservation ou la réalisation de la valeur. Ils diffèrent des **événements positifs**, c'est-à-dire des événements dans lesquels le rendement dépasse l'objectif initial.

- **Les méthodes** et **approches d'**identification des risques comprennent (1) les activités quotidiennes (p. ex. budgétisation, planification des activités ou examen des plaintes des clients), (2) de simples questionnaires, (3) des ateliers animés, (4) des entrevues ou (5) le suivi des données.
- L'**inventaire des risques** comprend tous les risques qui pourraient affecter l'entité.
- L'identification des risques et des opportunités doit être exhaustive à tous les niveaux et dans toutes les fonctions de l'entité.

ii *L'organisation évalue la **gravité du risque**. La gravité est une mesure de considérations telles que l'impact, la probabilité et le temps nécessaire pour se remettre d'événements*.

- Les mesures courantes de la gravité comprennent des combinaisons d'impact et de probabilité.
  - ✓ **L'impact** est le résultat ou l'effet du risque. L'impact peut être positif ou négatif.
  - ✓ **La probabilité** est la possibilité qu'un événement se produise. La probabilité peut être exprimée de façon qualitative (p. ex. une probabilité éloignée), quantitative (p. ex. une probabilité de 75 %) ou en termes de fréquence (p. ex. une fois tous les six mois).
- L'**horizon temporel d'**évaluation du risque devrait être identique à celui de la stratégie et de l'objectif opérationnel connexes. Par exemple, le risque affectant une stratégie qui prend 2 ans à réaliser devrait être évalué sur la même période.
- Le risque est évalué à **plusieurs niveaux** (p. ex., entité, division, unité opérationnelle et fonction) de l'organisation et est lié à la stratégie et à l'objectif opérationnel connexe.
- La gravité d'un risque peut varier d'un niveau à l'autre. Par exemple, un risque de gravité élevée au niveau de l'unité opérationnelle peut avoir une gravité faible ou modérée au niveau de l'entité.
- Des méthodes qualitatives et quantitatives peuvent être utilisées pour évaluer les risques.
  - ✓ Les méthodes **qualitatives** sont plus efficaces et moins coûteuses que les méthodes quantitatives. Par exemple, les entrevues, les sondages et l'analyse comparative.
  - ✓ Les méthodes **quantitatives** sont plus précises que les méthodes qualitatives. Les arbres de décision, la modélisation (probabiliste et non probabiliste) et la simulation de Monte Carlo en sont des exemples.
- L'organisation devrait **réévaluer la gravité** chaque fois que des événements déclencheurs surviennent, comme des changements dans le contexte commercial et la propension au risque.

- L'évaluation des risques devrait tenir compte du risque inhérent, du risque résiduel cible et du risque résiduel réel.
- Les résultats de l'évaluation peuvent être présentés à l'aide d'une **carte thermique** qui met en évidence la gravité relative de chaque risque. Plus la couleur est chaude, plus le risque est élevé.



iii *L'organisation **priorise les risques à** tous les niveaux*.

- La priorisation des risques permet à l'organisation d'optimiser l'affectation de ses ressources limitées.
- En plus de la gravité (p. ex., impact et probabilité), les facteurs suivants sont pris en compte lors de la priorisation des risques :
  - ✓ Critères convenus
  - ✓ Aptitude au risque
  - ✓ L'importance des objectifs opérationnels touchés
  - ✓ Le(s) niveau(x) organisationnel(s) touché(s)
- **Des critères convenus** sont utilisés pour évaluer les caractéristiques des risques et déterminer la capacité de l'entité à réagir de manière appropriée. Une priorité plus élevée est accordée aux risques qui affectent le plus les critères. Voici quelques exemples de critères :
  - ✓ **La complexité** est la nature et la portée d'un risque, p. ex. l'interdépendance des risques.
  - ✓ **La vitesse** est la vitesse à laquelle un risque affecte l'entité.
  - ✓ **La persistance** est la durée pendant laquelle un risque affecte l'entité, y compris le **temps** qu'il faut à l'entité pour se rétablir.
  - ✓ **La capacité d'adaptation** est la capacité de l'entité à s'adapter et à réagir aux risques.

- ✓ **Le rétablissement** est la capacité de l'entité (et non le moment) de revenir à la tolérance.

- Une priorité plus élevée est également accordée aux risques qui
  - ✓ Approcher ou dépasser l'appétit pour le risque,
  - ✓ Faire en sorte que les niveaux de performance approchent les limites extérieures de tolérance, où
  - ✓ Affectent l'ensemble de l'entité ou se produisent au niveau de l'entité.

iv *L'organisation détermine et sélectionne les **réponses aux risques**, en reconnaissant que les risques peuvent être gérés mais non éliminés. Les risques doivent être gérés dans le contexte et les objectifs de l'entreprise, les cibles de rendement et l'appétit pour le risque*.

- Voici les cinq catégories de réactions aux risques :
  - ✓ **Acceptation.** Aucune mesure n'est prise pour modifier la gravité du risque. L'acceptation est appropriée lorsque le risque se situe dans les limites de l'appétit pour le risque.
  - ✓ **Évitement. Des** mesures sont prises pour éliminer le risque (p. ex. l'abandon d'une gamme de produits ou la vente d'une filiale). L'évitement suggère généralement que l'absence d'intervention réduirait le risque à un niveau acceptable. iii)
  - ✓ **Poursuite. Des** mesures sont prises pour accepter un risque accru afin d'améliorer le rendement sans dépasser la tolérance acceptable.
  - ✓ **Réduction.** Des mesures sont prises pour réduire la gravité du risque afin qu'il se situe dans les limites du profil de risque résiduel et de l'appétit pour le risque visé.
  - ✓ **Partager. Des** mesures sont prises pour réduire la gravité du risque en transférant une partie du risque à une autre partie. Par exemple, l'assurance, les opérations de couverture, les coentreprises et l'impartition.

- Voici les **facteurs** pris en compte dans le choix et la mise en œuvre des mesures d'atténuation des risques :
  - ✓ Ils doivent être choisis ou adaptés au **contexte de** l'**entreprise**.
  - ✓ **Les coûts et les avantages** devraient être proportionnels à la gravité du risque et à sa priorité.
  - ✓ Ils devraient favoriser le **respect des** obligations (p. ex., les normes de l'industrie) et la réalisation des **attentes** (p. ex., mission, vision et attentes des intervenants).
  - ✓ Ils devraient intégrer le risque dans l'**appétit pour le risque** et produire des résultats de rendement conformes à la **tolérance**.
  - ✓ La réaction au risque devrait refléter la gravité du risque.

- **Les activités de contrôle** sont conçues et mises en œuvre pour s'assurer que les réponses aux risques sont mises en œuvre. (Les lignes directrices du COSO pour les activités de contrôle sont décrites dans la sous-unité 3 de la tranche d'étude 5).

v *L'organisation élabore et évalue sa **vision du risque pour** son **portefeuille**.*

- Le point culminant de l'identification, de l'évaluation, de la priorisation et de l'intervention des risques est la vue d'ensemble du portefeuille des risques.
- Les quatre points de vue suivants sur les risques présentent différents niveaux d'intégration des risques :
  - ✓ **Vue du risque (intégration minimale).** Les risques sont identifiés et évalués. L'accent est mis sur l'événement et non sur l'objectif commercial.
  - ✓ **Vue des catégories de risques (intégration limitée).** Les risques identifiés et évalués sont catégorisés, p. ex. en fonction des structures d'exploitation.
  - ✓ **Vue du profil de risque (intégration partielle). Les** risques sont liés aux objectifs opérationnels qu'ils touchent, et toute dépendance entre les objectifs est identifiée et **évaluée**. Par exemple, un objectif d'augmentation des ventes peut dépendre d'un objectif d'introduction d'une nouvelle gamme de produits.
  - ✓ **Vue du portefeuille (intégration complète).** Cette vision composite des risques est liée à la stratégie et aux objectifs commerciaux de **l'ensemble de l'entité** et à leur effet sur la performance de **l'entité.** Au niveau supérieur, l'accent est mis sur la stratégie. Ainsi, la responsabilité des objectifs commerciaux et des risques spécifiques **se répercute sur** l'entité.
- En se fondant sur une vue du risque du portefeuille, la direction détermine si le **profil de risque résiduel de** l'entité (profil de risque, y compris les réactions au risque) correspond à l'**appétit** général **pour le risque**.
- Des méthodes qualitatives et quantitatives peuvent être utilisées pour évaluer la façon dont les variations du risque peuvent influer sur la perception du risque par le portefeuille.
  - ✓ Les méthodes **qualitatives** comprennent l'analyse comparative, l'analyse de scénarios et les simulations de crise.
  - ✓ Les méthodes **quantitatives** comprennent l'analyse statistique.

8. Examen et révision

L'organisation examine et révise ses capacités et ses pratiques actuelles de GRE en fonction des changements de stratégie et d'objectifs opérationnels. **Trois principes** ont trait à l'examen et à la révision :

i *L'organisation détermine et évalue les **changements** qui peuvent avoir une incidence importante sur la stratégie et les objectifs opérationnels.*

- Les changements dans le **contexte** et la **culture d'affaires de** l'organisation sont les plus susceptibles d'influer considérablement sur la stratégie et les objectifs opérationnels.

- De tels changements peuvent résulter de changements dans l'environnement interne ou externe de l'organisation.
  - ✓ Les changements importants dans l'**environnement interne** comprennent ceux qui sont dus à la croissance rapide, à l'innovation et au roulement du personnel clé.
  - ✓ Les changements substantiels de l'**environnement externe** comprennent ceux de l'économie ou de la réglementation.

ii *L'organisation examine les résultats de **rendement de l'entité** et tient compte des **risques**.*

- Les résultats de rendement qui s'écartent du rendement ou de la tolérance cible peuvent indiquer (1) des risques non identifiés, (2) des risques mal évalués, (3) de nouveaux risques, (4) la possibilité d'accepter plus de risques, ou (5) la nécessité de réviser le rendement ou la tolérance cible.

iii *L'organisation poursuit l'**amélioration de** la GRE.*

- L'organisation doit continuellement améliorer la GRE à tous les niveaux, même si le rendement réel s'aligne sur le rendement cible ou la tolérance.
- Les méthodes d'identification des domaines à améliorer comprennent des **évaluations continues** ou **distinctes** et des comparaisons entre pairs (examens de pairs de l'industrie). (Les lignes directrices du COSO pour les activités de surveillance sont décrites dans la sous-unité 3 de la tranche d'étude 5).

9. Information, communication et reporting

L'organisation doit saisir, traiter, gérer (organiser et stocker) et communiquer de l'information opportune et pertinente afin de **cerner les risques** qui pourraient influer sur la stratégie et les objectifs opérationnels. **Trois principes** ont trait à l'information, à la communication et à l'établissement de rapports :

i *L'organisation tire parti de ses **systèmes d'information** pour appuyer la GRE.*

- **Les données** sont des faits bruts qui peuvent être recueillis à des fins d'analyse, d'utilisation ou de référence. L'**information** est traitée, organisée et structurée à partir de données sur un fait ou une circonstance. Les systèmes d'information transforment les données (p. ex., les données sur les risques) en information pertinente (p. ex., l'information sur les risques).
  - ✓ **La connaissance** est une donnée transformée en information.
  - ✓ L'information est **pertinente** si elle aide l'organisation à être plus agile dans la prise de décision, ce qui lui donne un avantage concurrentiel.
- Les données **structurées** sont généralement bien organisées et faciles à consulter (p. ex. feuilles de calcul, index publics ou fichiers de base de données).
  - ✓ Les données **non structurées ne** sont pas organisées ou n'ont pas de modèle prédéfini (p. ex. documents de traitement de texte, vidéos, photos ou messages électroniques).

- Les pratiques de **gestion des données** permettent de s'assurer que l'information sur les risques est utile, opportune, pertinente et de grande qualité. Voici les éléments d'une gestion efficace des données :
  - ✓ **Gouvernance des données et de l'information.** Les normes sont établies pour la livraison, la qualité, l'actualité, la sécurité et l'architecture des données. Les rôles et les responsabilités sont également définis pour les propriétaires de l'information sur les risques et les propriétaires des données.
  - ✓ **Processus et contrôles. Des** activités sont mises en œuvre pour s'assurer que les normes de données établies sont renforcées et que des corrections sont apportées au besoin.
  - ✓ **Architecture de gestion des données.** La technologie de l'information est conçue pour déterminer quelles données sont recueillies et comment elles sont utilisées.
- Les systèmes d'information doivent **pouvoir s'adapter au changement**. Au fur et à mesure que l'organisation adapte sa stratégie et ses objectifs d'affaires en fonction de l'évolution du contexte opérationnel, ses systèmes d'information doivent aussi changer.

ii *L'organisation utilise des **canaux de communication** pour soutenir la GRE*.

- Communications sur les risques.
  - ✓ La direction communique la stratégie et les objectifs opérationnels de l'organisation aux intervenants internes (p. ex. le personnel et le conseil) et externes (p. ex. les actionnaires).
  - ✓ Les communications entre la direction et le conseil devraient comprendre des discussions continues sur l'**appétit pour le risque**.
- Canaux et méthodes.
  - ✓ Les organisations devraient adopter des **voies de communication ouvertes pour** permettre l'envoi et la réception de l'information sur les risques dans les deux sens (p. ex. à destination et en provenance du personnel ou des fournisseurs).
  - ✓ **Les méthodes de** communication comprennent les documents écrits (p. ex., politiques et procédures), les messages électroniques (p. ex., courriel), les événements ou forums publics (p. ex., assemblées publiques) et les communications informelles ou verbales (p. ex., discussions individuelles).
  - ✓ Le conseil peut tenir des réunions trimestrielles **officielles** ou tenir des réunions **extraordinaires** (réunions spéciales pour discuter des questions urgentes).

iii *L'organisation **rend compte des** risques, de la culture et du rendement à de multiples niveaux et dans l'ensemble de l'entité*.

- L'objectif des rapports est d'**aider le** personnel de **soutien** dans son travail.
  - ✓ Compréhension des relations entre le risque, la culture et le rendement.

- ✓ La prise de décision concernait (a) l'établissement de la stratégie et des objectifs, (b) la gouvernance et (c) les opérations quotidiennes.

- Les rapports combinent des renseignements qualitatifs et quantitatifs sur les risques, en mettant davantage l'accent sur l'information qui appuie les décisions **prospectives.**
- **La direction** est responsable de la mise en œuvre de **contrôles** pour s'assurer que les rapports sont exacts, complets et clairs.
- La **fréquence des rapports** dépend de la gravité et de la priorité du risque.
- Les rapports sur la **culture** peuvent être communiqués, entre autres, dans le cadre d'enquêtes et d'analyses des leçons apprises.
- **Les principaux indicateurs de risque** devraient être présentés avec les indicateurs de rendement clés pour mettre l'accent sur la relation entre le risque et le rendement.

10. Évaluation de la GRE

Le cadre du COSO ERM fournit des critères pour évaluer si la culture, les capacités et les pratiques de GRE de l'organisation permettent de gérer efficacement les risques liés à la stratégie et aux objectifs opérationnels.

Lorsque les **composantes**, les **principes** et les **contrôles à** l'appui sont présents et fonctionnent, on s'**attend raisonnablement à ce que la** GRE gère les risques efficacement et aide à créer, préserver et réaliser de la **valeur**.

- **Présent** signifie que les composantes, les principes et les contrôles existent dans la conception et la mise en œuvre de la GRE pour atteindre les objectifs.
- **Le fonctionnement** signifie que les composantes, les principes et les contrôles continuent de fonctionner pour atteindre les objectifs.

III. CADRE DE GESTION DES RISQUES ISO 31000

1. ISO 31000 - Principes, cadre et processus

La GRE du COSO est basé sur des objectifs. En revanche, ISO 31000 est une approche de management des risques basée sur des principes. Il énonce des principes qui sont à la base d'un processus efficace de management des risques. La Gestion des risques :

- Est une activité à valeur ajoutée.
- Ne peut se dissocier des opérations et des processus de prise de décision de l'organisation.
- Traite de l'incertitude de façon structurée, ordonnée, sans ambiguïté et en temps opportun.
- Utilise les meilleures informations disponibles.
- Est adaptée à l'environnement d'exploitation, la culture et les objectifs de l'organisation.
- Est transparente, vérifiable et inclut les parties prenantes.

- Utilise un cycle itératif pour favoriser une amélioration continue, les connaissances au niveau organisationnel et la capacité à rapidement tenir compte des changements au niveau des environnements.

Un cadre de management des risques est un ensemble d'éléments qui fournissent les bases et les dispositions organisationnelles pour la conception, la mise en œuvre, le suivi, l'examen et l'amélioration continue du management des risques dans l'organisation.

Un mandat et un engagement du conseil d'administration et de la direction générale garantissent que les processus de management des risques sont conformes aux objectifs de l'organisation et que des ressources suffisantes ont été affectées à son succès.

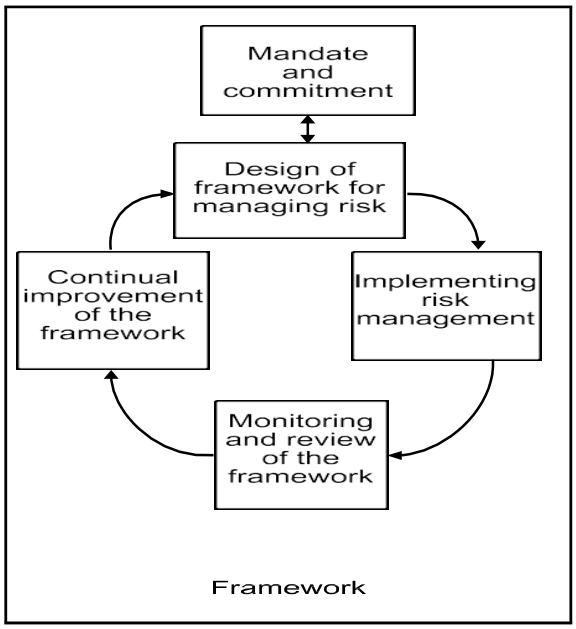
La conception d'un cadre de management des risques permet de jeter les bases d'un processus efficace de management des risques. Cette fondation implique

- Comprendre l'organisation et son contexte
- Établir une politique de management des risques
- Déléguer la responsabilité et l'autorité
- Intégrer le management des risques dans les processus organisationnels
- Allouer les ressources nécessaires
- Établir des communications internes et externes et les méthodes de reporting

La mise en œuvre du management des risques aide l'organisation à atteindre ses objectifs.

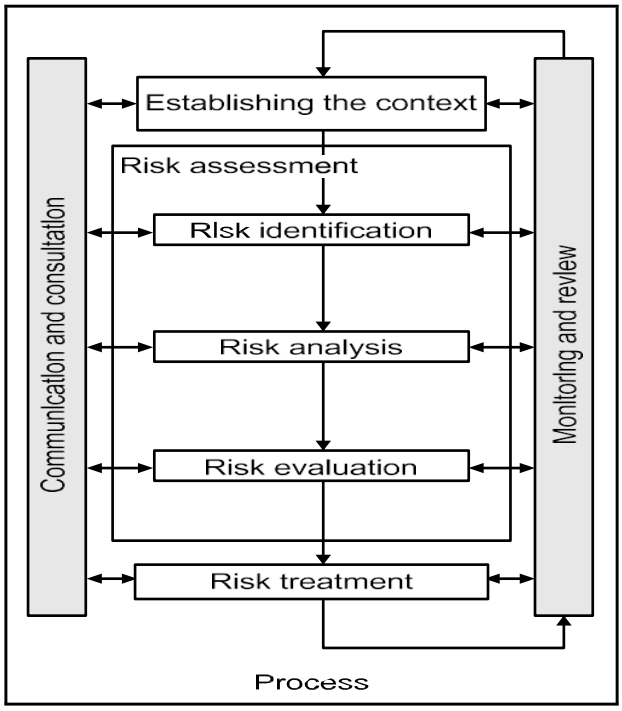
Le suivi et l'examen du cadre évaluent l'efficacité des processus de management des risques.

L'amélioration continue du cadre garantit l'efficacité à long terme des processus de management des risques.



Le processus de management des risques ISO 31000 comprend les sept éléments suivants :

- La communication et la consultation nécessitent une communication et une consultation continue et structurées avec les personnes affectées par les opérations de l'organisation.
- L'établissement du contexte identifie et comprend les facteurs externes et internes qui influenceront le management des risques de l'organisation. Cet élément tient également compte des niveaux d'appétence pour le risque et de tolérance au risque de l'organisation.
- L'identification des risques prend en compte les sources de risque, les zones d'impact et les événements potentiels ainsi que leurs causes et conséquences.
- L'analyse des risques prend en compte l'impact et la probabilité de chaque risque.
- L'évaluation des risques donne la priorité aux risques identifiés.
- Le traitement du risque décide d'une réponse au risque appropriée (éviter, partager, réduire ou accepter) qui est compatible avec l'appétence pour le risque de l'organisation.
- Surveillance et examen permettent d'évaluer si les traitements des risques sont efficaces.



2. ISO 31000 - Responsabilités pour le management des risques

Le conseil est responsable de la supervision du management des risques et a la responsabilité globale de s'assurer que les risques sont gérés et que le système de management des risques est efficace. La direction est responsable de définir l'attitude de risque de l'organisation, qui est définie par l'ISO comme « l'approche de l'organisation pour évaluer, puis poursuivre, conserver, prendre ou se détourner du risque ». La direction identifie et gère également les risques. L'activité d'audit interne est chargée de fournir une assurance concernant l'ensemble du système de management des risques.

3. ISO 31000 - Approches d'assurance

ISO 31000 décrit trois approches pour fournir une assurance sur le processus de management des risques : (1) les principes clés, (2) l'élément de processus, et (3) le modèle de maturité.

L'approche des principes clés évalue si les 11 principes de management des risques sont mis en pratique.

L'approche des éléments de processus évalue si les sept éléments de management des risques ont été mis en pratique.

L'approche du modèle de maturité est basée sur le principe selon lequel les processus efficaces de management des risques se développent et s'améliorent avec le temps, à mesure que de la valeur est ajoutée à chaque étape du processus de maturation.

En conséquence, cette approche détermine où se situe le processus de management des risques sur la courbe des échéances et évalue si (1) elle progresse comme prévu, (2) ajoute de la valeur et (3) répond aux besoins organisationnels.

Un exemple de courbe de maturité (c'est-à-dire le modèle de maturité) est le modèle de maturité de capacité (CMM). Ce modèle comprend les cinq niveaux de maturité suivants, présentés par ordre de maturité : (a) initial, (b) répétable, (c) défini, (d) géré et (e) optimisé.

- **Niveau 1—Initial** : Les organisations à ce niveau ne disposent pas de politiques ou de procédures définies. Ces organisations font preuve d'un manque d'intérêt ou d'engagement de la part de la direction et des employés.
- **Niveau 2—Reproductible** : ces organisations bénéficient d'une politique définie et d'un certain engagement de la part de la direction et des employés.
- **Niveau 3—Défini** : Une politique est établie et la direction générale s'engage à la mettre en œuvre. Des risques ont été évalués, des priorités établies, des ressources attribuées et des activités effectuées ou développées pour assurer des contrôles cohérents.
- **Niveau 4—Maîtrisé** : Les exigences et les contrôles font partie intégrante du cadre de l'organisation. Toutes les parties de l'organisation se sont engagées.
- **Niveau 5—Optimisé** : Le cadre à des fins d'amélioration continue. Toute action corrective est abordée par l'ensemble des parties concernées de l'organisation et aucune modification n'est apportée sans une coordination étendue.

Le principe de base de cette approche est que le management des risques doit ajouter de la valeur. Un aspect essentiel de l'approche du modèle de maturité est que la performance du management des risques et les progrès réalisés dans l'exécution du plan de management des risques doivent être liés à un système de mesure de la performance. Un tel système de performance consiste typiquement en ce qui suit :

- Normes de performance.
- Critères sur la façon dont les normes peuvent être satisfaites.
- Une méthode de comparaison des performances réelles avec chaque norme.
- Une méthode d'enregistrement et de reporting des performances et d'amélioration de la performance.

- Vérification indépendante périodique de l'évaluation de la direction.

4. Cadre de management des risques de Turnbull

Contrairement à l'approche fondée sur les objectifs du COSO ERM et à l'approche fondée sur les principes ISO 31000, le cadre de management des risques de Turnbull met l'accent sur le contrôle interne, l'évaluation de son efficacité et l'analyse des risques.

Le « Guide de contrôle interne pour les administrateurs sur le Combined Code » (Internal Control Guidance for Directors on the Combined Code) a été publié en 1999 au Royaume-Uni. Les termes « Recommandations Turnbull » ou « Turnbull » sont souvent utilisés pour faire référence à cette publication qui porte le nom de Nigel Turnbull, le président du groupe de travail qui a élaboré ces directives de gestion des risques. L'ouvrage a été révisé en 2005 pour refléter les différents développements au Royaume-Uni et sur la scène internationale et intégrer l'expérience acquise dans le cadre des mises en œuvre. En 2014, le Conseil de l'information financière (FRC) a publié un rapport mis à jour, intitulé « Conseils sur la gestion des risques, le contrôle interne et les rapports financiers et commerciaux connexes », qui a révisé, intégré et remplacé l'édition 2005 de Turnbull Guidance.

Les Recommandations Turnbull traitent de l'adoption d'une approche du contrôle interne fondée sur le risque et de l'évaluation de son efficacité. Elles sont liées aux exigences de divulgation de la Bourse de Londres. Le rapport Turnbull recommande à toutes les entreprises répertoriées à la Bourse de Londres de mettre en place un plan de gestion des risques. Bien que les détails de mise en œuvre spécifiques soient laissés à la discrétion de l'entreprise, la direction exige que le plan soit mis en place et géré activement. Comme pour les exigences imposées par la loi Sarbanes-Oxley de 2002, les règlements associés de l'US Securities and Exchange Commission (SEC) et les règlements de la Bourse américaine, si l'on ne se conforme pas aux Recommandations Turnbull, les informations seront publiées dans le rapport annuel. En fait, la SEC considère les Recommandations Turnbull comme étant un cadre approprié pour se conformer aux exigences des États-Unis concernant le reporting des contrôles internes relatifs à l'information financière, comme indiqué dans la Section 404 de la loi Sarbanes-Oxley et les règlements associés de la SEC.

Toutefois, les Recommandations Turnbull ne sont pas seulement utilisées afin de se conformer aux modalités définies par la Bourse. Les principes de gestion efficace des risques et d'intégration d'un contrôle interne au niveau des processus d'entreprise présentent un grand intérêt commercial pour une entité. Les organisations ont la possibilité de sélectionner les principes adaptés à leurs propres circonstances. Voici quelques-uns des principes clés des Recommandations Turnbull :

- **Mettre l'accent sur les risques importants**. Si trop de risques sont identifiés, il devient difficile d'identifier et de gérer ceux qui sont importants. Turnbull recommande que l'identification des risques se concentre sur les risques qui ont été identifiés par la direction générale comme étant potentiellement dangereux pour la réalisation des objectifs de l'organisation.
- **Mettre l'accent sur la gestion des risques**. Turnbull considère la gestion du risque comme essentielle pour réduire la probabilité que les objectifs organisationnels soient mis en péril

par des événements imprévus. Les Recommandations favorisent la gestion proactive des risques.

- **Surveillance continue des risques et du contrôle**. Les stratégies et les politiques de gestion des risques et de contrôle interne d'une organisation doivent être surveillés en permanence et adaptés pour répondre à l'évolution des risques. Un processus de feedback doit être mis en place pour tirer les leçons des échecs et développer les capacités permettant de potentiellement s'améliorer et réduire le risque.
- **Faire participer tous les employés**. Turnbull maintient que tous les employés ont une certaine responsabilité quant au contrôle interne et doivent être responsabilisés pour atteindre les objectifs organisationnels. Ils doivent disposer des connaissances, des compétences, des informations et de l'autorité nécessaires pour établir, utiliser et surveiller le système de contrôles internes dans leur sphère de responsabilités. Ils doivent comprendre les objectifs organisationnels et les industries et les marchés spécifiques à l'entité ainsi que les risques auxquels elle est confrontée.
- **Rationalisation des bases de données de gestion des risques**. Le contrôle devrait être intégré dans les processus organisationnels. Le rapport Turnbull recommande d'intégrer des mécanismes de détection précoce aux systèmes d'information de la direction existants plutôt que de développer des systèmes de reporting des risques indépendants.

Grâce à cet aperçu des Recommandations Turnbull, nous pouvons constater qu'il existe beaucoup de similarités au niveau des différentes approches de gestion des risques présentées. Et comme pour les cadres de l'ERM du COSO et de la norme ISO 31000, une organisation peut tirer parti de l'adoption de l'approche Turnbull fondée sur les risques. Certains aspects positifs permettent de mieux :

- Fournir une assurance objective au conseil et à la direction générale quant à l'adéquation et à l'efficacité des processus de contrôle interne et de gestion des risques de l'organisation.
- Donner des conseils en matière de gestion efficace des risques, en particulier en ce qui concerne les problèmes liés à la conception, à la mise en œuvre et à l'exploitation des systèmes de contrôles internes.
- Identifier les possibilités de réaliser des économies sur les coûts du contrôle et/ou d'éviter les pertes opérationnelles et autres pertes similaires.
- Réduire la probabilité d'occurrence d'événements indésirables.

Pour plus d'informations sur les recommandations Turnbull de 2005 et l'édition FRC 2014 suivante, visitez https://fr.frc.org.uk/